

디지털 보안

1. 정보보안 기본

kpc

한국생산성본부

KPC 정보관리기술사 기본반



1. 정보보안 기본

정보보호개론.....	4
OWASP(The Open Web Application Security Project).....	7
OAuth 2.0	10
접근제어(Access Control).....	12

정보보호개론

1. 정보보호(Information Security)의 개요

□ 정보보호(Information Security)의 정의

- 의도적 또는 비의도적으로 부당한 정보의 **열람, 유출, 변조, 파괴**로부터 정보를 보호하고자 하는 활동
- 정보의 수집·가공·저장·검색·송신·수신 중에 정보의 **훼손·변조·유출** 등을 방지하기 위한 관리적·기술적 수단, 또는 그러한 수단으로 이루어지는 행위

2. 보안의 3요소 및 정보보호 관련 주요 용어

□ 보안의 3요소

요소	설명
기밀성	- 정보가 노출되는 것을 방지하는 것으로 기밀성을 높이기 위해 정보를 암호화
가용성	- 권한이 있는 사람은 언제, 어디서든 정보에 접근 가능한 것 - 가용성을 높이기 위해 권한을 세분화
무결성	- 정보의 변조나 파괴를 방지하는 것으로 무결성을 높이기 위해 권한 부여를 강화

정보보호개론

□ 정보보호 관련 주요 용어

용어	설명
자산(Asset)	- 조직/기업의 가치 있는 자원들
위협(Threat)	- 조직/기업 자산에 악영향을 끼칠 수 있는 조건/사건/행위
취약점(Vulnerability)	- 위협이 발생하기 위한 사전 조건이나 상황으로 물리적, 자연적, 환경적, 하드웨어적, 소프트웨어적, 매체, 통신, 인적 자원에 대한 취약점
위험(Risk)	- 위협이 취약점을 이용하여 조직의 자산에 손실, 피해를 일으킬 가능성
보호(Protection)	- 위험으로부터 자산을 지키는 것
보안(Security)	- 테러, 절도 등 주로 고의적인 행위 등에 의한 외부 침해로부터의 보호

정보보호개론

3. 정보보호 분류

□ 구현 방법에 따른 분류

구분	설명
물리적 보안	- 물리적 위협수단(사람, 물품, 차량 등)으로부터 보호하기 위한 물리적 수단에 의해 이루어지는 보안관리
관리적 보안	- 정보자산에 대한 기업의 정보보호 활동에 대한 정책, 표준, 지침, 절차를 정의하고 이를 실행, 감독하는 활동
기술적 보안	- 정보 시스템에 존재하는 취약점을 제거하고 정보 시스템에 발생할 수 있는 외부로부터의 보안 위협을 차단하기 위해 정보보호 시스템 구축, 운영하는 활동

정보보호개론

□ 적용시점에 따른 분류

분류	설명	주요활동
예방통제	- 위협에 대한 사전 예방 행위	- 접근통제, 파일백업, 직원훈련, 보안의식 고취 등
탐지통제	- 예방통제를 우회 발생한 위험 통제	- 침입탐지시스템, 바이러스 탐지, ESM ¹ 등
교정통제	- 탐지통제를 통해 발견된 위협을 해결, 피해의 원상회복	- 복구절차, 연속성 계획, 사고처리
저지통제	- 물리적인 접근 통제	- 입/출입 통제, 생체인식, CCTV 등

OWASP(The Open Web Application Security Project)

1. 국제 웹 보안 표준 기구, OWASP 개요.

□ OWASP (The Open Web Application Security Project)의 정의

- 국제웹보안 표준기구, 정보누출, 인젝션 결함, 악성파일, 보안취약점 등 연구 안내 커뮤니티
- 웹 애플리케이션 취약점 중 공격 빈도가 높으며, 보안상 큰 영향을 줄 수 있는 10가지 취약점에 대응 방안을 제공하는 웹 보안 기술 가이드

□ OWASP Top 10의 특징

관점	특징
개발자 측면	- 웹 애플리케이션 보안 요구사항의 숙지 및 준수 - 웹 애플리케이션 보안 아키텍처의 수립 - OWASP TOP 10을 기반으로 표준화된 보안 통제 기법 활용 - OWASP TOP 10을 이용한 웹 애플리케이션 개발자 보안 교육
관리자 측면	- 웹 애플리케이션 보안 검증 방법의 표준화 자료로 활용 - 평가 툴 기반의 웹 애플리케이션 전체에 걸친 보안상태 점검 - OWASP 기준의 코드 검토 및 보안과 침투 시험
조직 측면	- 정책과 표준을 제시하고 강력한 웹 애플리케이션 보안 통제 기반 수립 - 보안 구현과 검증 활동으로 기존 보안 관리 프로세스를 개선 - 웹 애플리케이션의 CSF(Critical Success Factors)를 제시

OWASP(The Open Web Application Security Project)

2. OWASP Top 10 2025 보안위협항목과 변경사항

□ OWASP Top10 2025 보안위협항목

순위	취약점	설명
A01	취약한 접근 통제 (Broken Access Control)	- 가장 심각한 위험으로 1 위 유지. 테스트된 애플리케이션의 3.73%에서 발견되었으며, 40 개의 CWE 를 포함. SSRF 가 이 항목으로 통합됨.
A02	보안 설정 오류 (Security Misconfiguration)	- 2 위로 상승. 설정 기반 동작이 증가하면서 더 만연해짐. 테스트된 애플리케이션의 3.00%에서 발견되었으며, 16 개의 CWE 를 포함.
A03	소프트웨어 공급망 실패 (Software Supply Chain Failures)	- A06:2021 (취약하고 오래된 구성요소)의 확장. 소프트웨어 종속성, 빌드 시스템 등 전체 생태계의 위험을 포괄. 커뮤니티 설문조사에서 최고 관심사로 선정됨. 데이터상으로는 발생 빈도가 가장 낮지만, CVE 의 평균 악용 및 영향 점수는 가장 높음.

OWASP(The Open Web Application Security Project)

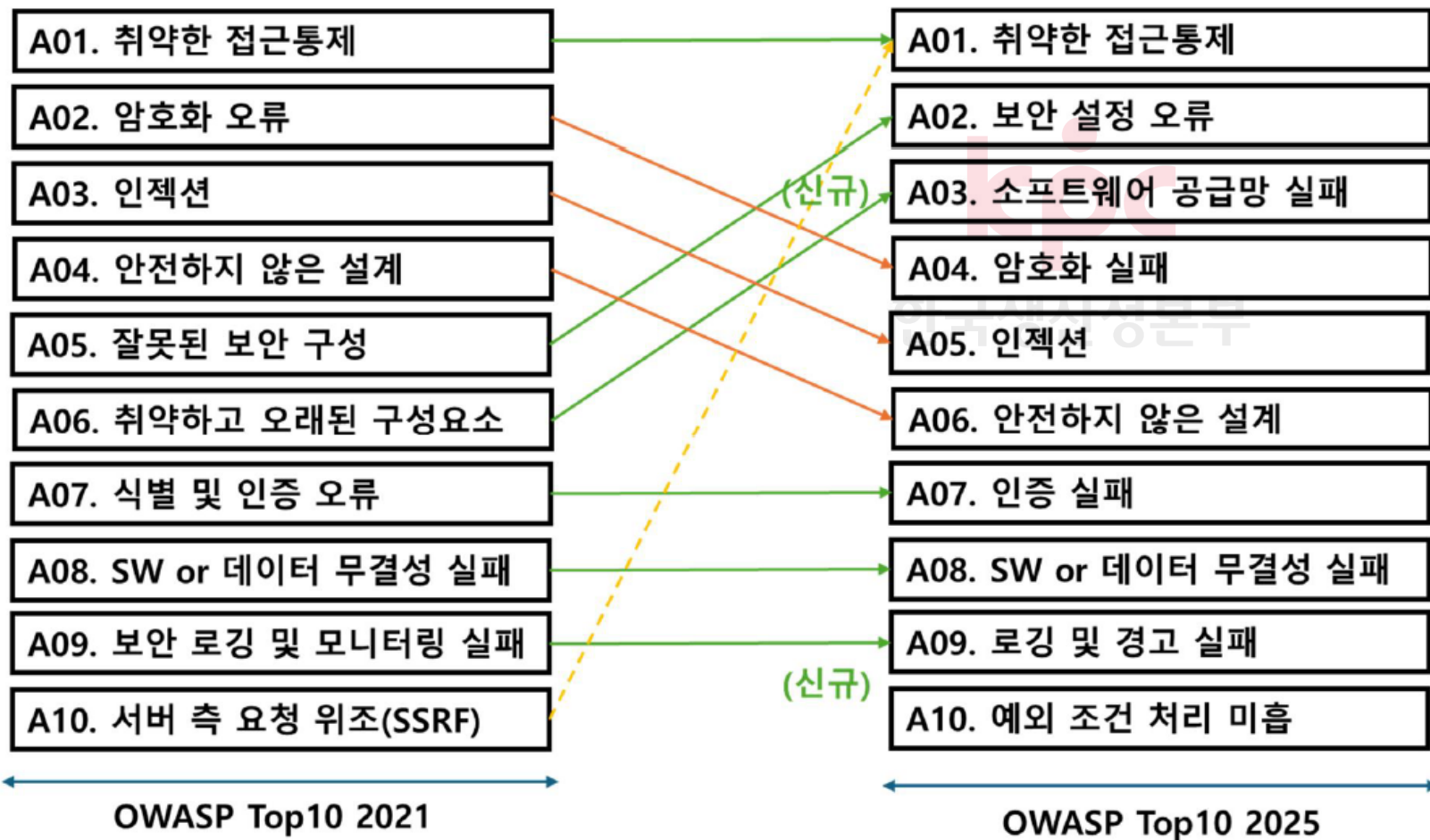
A04	암호화 실패 (Cryptographic Failures)	- 4 위로 하락. 테스트된 애플리케이션의 3.80%에서 발견. 민감 데이터 노출이나 시스템 침해로 이어지는 경우가 많음. 32 개의 CWE 를 포함.
A05	인젝션 (Injection)	- 5 위로 하락. 가장 많이 테스트되는 카테고리 중 하나. XSS 부터 SQL 인젝션까지 포함하며 38 개의 CWE 를 포함.
A06	안전하지 않은 설계 (Insecure Design)	- 6 위로 하락. 위협 모델링 및 보안 설계 강조로 업계 개선이 있었음.
A07	인증 실패 (Authentication Failures)	- 7 위 유지. (Identification and Authentication Failures 에서) 명칭이 약간 변경됨. 표준화된 인증 프레임워크 사용 증가로 발생률이 개선되는 추세. 36 개의 CWE 를 포함.

OWASP(The Open Web Application Security Project)

A08	소프트웨어 및 데이터 무결성 실패 (Software or Data Integrity Failures)	- 8 위 유지. 공급망 실패보다 낮은 수준에서 신뢰 경계를 유지하고 소프트웨어/데이터 무결성을 확인하는 데 중점을 둠.
A09	로깅 및 경고 실패 (Logging & Alerting Failures)	- 9위 유지. (Security Logging and Monitoring Failures에서) 경고(Alerting) 기능의 중요성을 강조하도록 명칭이 변경됨. 데이터에 과소평가되는 경향이 있어 커뮤니티 투표로 포함됨.
A10	예외 조건 처리 미흡 (Mishandling of Exceptional Conditions)	- 2025 년 신규 카테고리. 부적절한 오류 처리, 논리적 오류 등 시스템이 비정상적인 상황을 만날 때 발생하는 시나리오에 초점을 맞춤. 24 개의 CWE 를 포함.

OWASP(The Open Web Application Security Project)

□ OWASP Top10 2025 의 변경사항



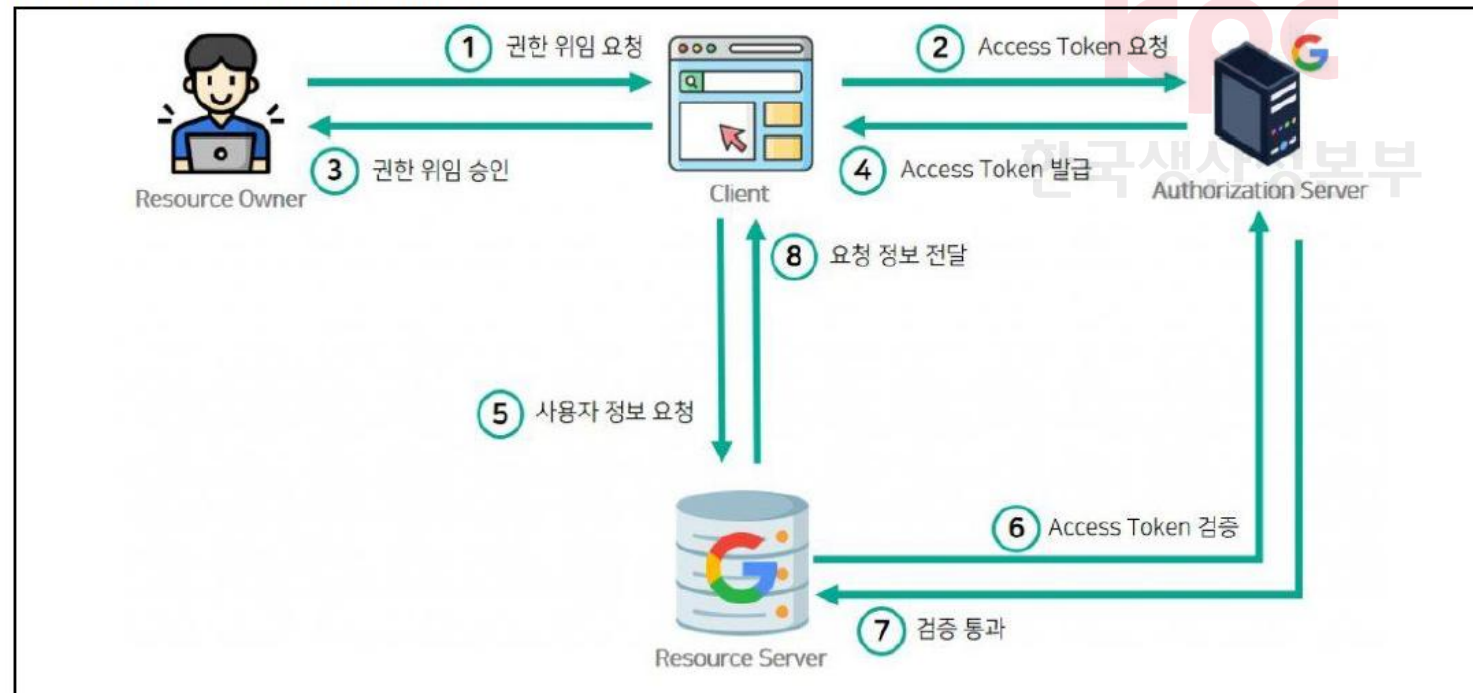
OAuth 2.0

1. 인증 및 권한부여, OAuth 2.0의 개요

- [개념] Access token을 통해 3rd party 리소스에 대한 제한적 접근권한 및 인증을 위한 범용적인 인증표준
- [표준] RFC 6749, 6750

2. OAuth 2.0의 Protocol Flow 및 권한승인 과정 상세설명

□ OAuth 2.0의 Protocol Flow



- 권한 획득 후 Access token을 통해서 자원의 제한적 접근 가능

OAuth 2.0

□ OAuth 2.0의 권한승인 과정 상세설명

단계	활동상세	설명
1	권한위임 요청	- 사용자인 Resource Owner는 소셜 로그인을 통해 클라이언트가 제공하는 서비스에 접근하고자 하며, 이를 위한 권한 위임을 요청
2	Access Token 요청	- 클라이언트(Client)는 Authorization Server에게 Resource Server가 보호하는 자원에 접근하기 위한 Access Token 발급을 요청. 이때, 사용자는 인증(로그인)을 위해 Authorization Server의 페이지로 이동
3	권한위임 승인	- 사용자는 클라이언트에 대한 권한 위임을 승인
4	Access Token 발급	- Authorization Server는 클라이언트에게 Access Token을 발급. - Access Token에는 만료기간이 설정되어 있음
5	사용자 정보 요청	- 클라이언트는 Resource Server에게 Access Token을 전달하여, 사용자의 정보에 접근을 요청
6	Access Token 검증	- Resource Server는 Access Token의 유효성을 확인하기 위해 이를 발급한 Authorization Server에 검증을 요청
7	검증 통과	- Authorization Server가 Access Token의 유효성을 확인하면, Resource Server에게 인증 성공 메시지를 전송
8	요청 정보 전달	- Resource Server는 클라이언트가 요청한 사용자 정보를 반환

OAuth 2.0

3. OAuth 2.0 의 보안취약점을 보완하는, OAuth 2.1

- 기존 2.0 의 보안 모범사례와 권장사항을 묶어서 새 버전으로 정리
- PKCE(Proof Key for Code Exchange) + Authorization Code Grant 사용
- 사용자 id/passwd 직접 받는 방식은 위험하므로 제외
- Refresh Token 재사용 감지(Reuse Detection)



접근제어(Access Control)

1. DAC, MAC, RBAC, 접근 제어의 개요.

□ 접근제어(Access Control)의 정의

- 정보시스템과 내부 자원에 대한 비인가된 접근 감시, 사용자 식별(인증), 접근 기록, 보안정책(Security Policy)에 근거하여 권한을 부여하는 기술 및 행정적인 관리(Administration: Accounting 개념 포함)를 총칭함
- 권한이 있는 사용자들에게만 특정 데이터 또는 자원들이 제공되는 것을 보장하기 위한 방법

□ 접근제어의 중요성

- 비인가자에 의한 불법적인 자원접근 및 파괴를 예방함
- 각 자원에 대한 기밀성, 무결성, 가용성 및 합법적인 이용성 제공함

접근제어(Access Control)

□ 접근통제정책 기본 원칙

직무분리의 원칙	최소권한의 원칙
- 정보의 접근을 위한 필요절차인 업무의 발생, 승인, 변경, 확인, 배포 등 모든 업무는 분리해서 처리해야 되며 한 사람이 할 수 없음	- 시스템의 주체들은 그들이 업무수행을 위해 필요한 최소한의 권한만 부여하여 피해를 최소화하도록 통제함

□ 접근통제정책 분류

- 신분 기반 정책 : IBP(Individual-Based Policy), GBP(Group-Based Policy)
- 규칙 기반 정책 : MLP(Multi-Level Policy), CBP(Compartment-Based Policy)
- 접근통제 메커니즘 : ACL(Access Control List), CL(Capability List), SL(Security List)
- 접근 통제 기술 : 강제적 접근 제어(MAC, Mandatory Access Control), 임의적 접근 제어(DAC, Discretionary Access Control), 역할 기반 접근 제어(RBAC, Role Based Access Control)

접근제어(Access Control)

2. 강제적 접근 제어(MAC)과 임의적 접근 제어(DAC)의 개요

□ 강제적 접근제어(MAC; Mandatory Access Control)

- 각 정보에 결합된 보안등급과 사용자에게 부여된 인가 등급을 사전에 규정된 규칙과 비교하여 그 규칙을 비교하여 만족하는 사용자에게만 접근 권한을 부여하는 보안정책
- 객체(보호대상 데이터베이스; DB, Table)에는 분류등급을 부여, 주체(사용자 또는 사용자 그룹)에는 인가등급 부여. 예) 군대의 계급별 인가 등급 예

□ 임의적 접근 제어(DAC; Discretionary Access Control)

- 사용자 본위로 접근 권한을 정의하는 방법
- 사용자 식별과 권한 인가에 기초한 접근 권한 제어 방식; 예) 각 사용자 별 권한 지정 방식
- 주체 중심의 권한 정의

□ MAC 과 DAC 의 한계점

- 사용자와 접근 권한 간의 1:1 매핑 구조
- 강제적 접근 제어의 경우, 보안등급 기준 설정이 모호한 경우에는 적용상의 한계 존재
- 임의적 접근 제어의 경우, 접근 권한에 대한 명백한 표현과 관리성에 대한 개선 필요로 하는 한계

접근제어(Access Control)

3. 역할기반(Role-based) 접근통제정책, RBAC 의 개요

□ RBAC 의 정의

- 사용자에게 직접 권한을 부여하는 대신(DAC방식), 사용자에게는 역할이 부여되고, 역할에 대해 수행을 위해 필요한 최소 자원만을 접근할 수 있도록 하는 보안 원리
- 조직 내에서 맡은 역할에 기초하여 자원에 대한 접근허용 여부가 결정됨

□ RBAC 의 특징(최소권한 원칙, 직무분리, 데이터추상화)

구 분	내 용
권한 관리	- Authorization Management - 사용자의 권한지정을 논리적/독립적으로 할당하거나 회수가 가능하여 보안 관리를 단순화 시켜줌
계층적인 역할분배	- Hierarchical Roles - 역할(Role)에 대한 계층을 두어 상속이 가능함 - 계층적인 역할은 권한에 대한 관리를 더욱 단순하게 함
최소권한 정책	- Least Privilege - 사용자에게 최소한의 필요한 권한만 부여함으로 권한의 남용 방지
임무의 분리	- Separation of Duty - 시스템상에 오용을 발생시킬 수 있는 충분한 권한을 갖는 사용자를 방지함
객체 분류	- Object Class - 수행하는 업무에 따라 사용자 분류 및 권한 제한이 가능

접근제어(Access Control)

4. 접근제어 정책의 비교

구분	MAC	DAC	RBAC
특징	강제적 통제	객체중심통제	그룹/Role 단위 통제
통제 기반	규칙기반(Rule Based)	신분기반(Identity Based)	역할기반(Role Based)
통제주체	시스템	객체 Owner	Administrator
구성요소	Clearance(승인), Security Level Need to know(필지(必知) 사항)	ACL(list)	Role Group Need to know
장점	보안성 매우 높음	구현용이, 유연성	구성변경용이
활용	군, 정부	대부분 OS	조직, 기업, ERP 등

디지털 보안

2. 암호학

kpc

한국생산성본부

KPC 정보관리기술사 기본반



2. 암호학

암호화(Encryption).....	16
공개키(public key) 기법	21
DES(Data Encryption Standard).....	23
SPN(Substitution - Permutation Network).....	27
AES(Advanced Encryption Standard).....	31
해쉬함수(Hash function)	34
양자암호통신(Quantum Cryptography Communication)	38
양자내성암호(Post-Quantum Cryptography).....	40

암호화(Encryption)

1. 데이터의 안전한 교환과 저장을 위한 보안 알고리즘, 암호화의 개요

□ 암호화(Encryption)의 정의

- 메시지의 내용이 불명확하도록 평문(Plain text)을 재구성하여 암호화된 문장(Cipher text)으로 만드는 과정

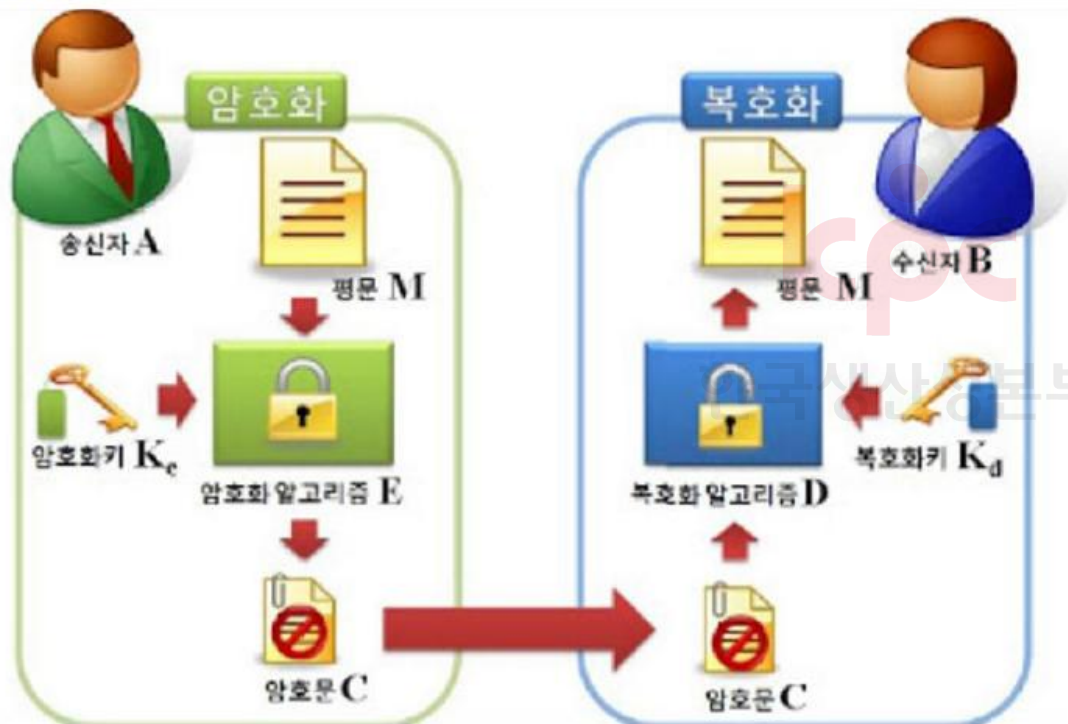
□ 암호화의 특성

특성	기능	적용기술
인증(Authentication)	- PKI 사용자에게 대한 신원 확인 기능	인증서
기밀성(Confidentiality)	- 송/수신자 이외는 송신내용 인지불가	암/복호화
무결성(Integrity)	- 정보의 조작 및 변경 여부 확인	해쉬함수
부인봉쇄(Non-repudiation)	- 송수신자의 송수신 사실 부인 봉쇄	전자서명
가용성(Availability)	- 정합한 요구시 서비스 제공	암호/인증

암호화(Encryption)

2. 암호 시스템

□ 암호화/복호화 개념도



- 침해자는 암호키가 없기 때문에 암호문을 파악할 수 없음

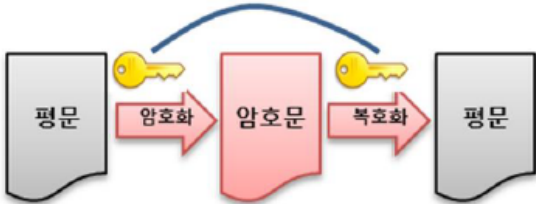
암호화(Encryption)

□ 암호화 구성요소

구성요소	내용
평문(Plain-text)	- 암호화 하고자 하는 문장
암호문(Cipher-text)	- 평문을 암호화 알고리즘과 키를 이용하여 암호화한 문장
암호화(Encryption)	- 평문을 암호화 키를 이용하여 암호문으로 변환시키는 과정
복호화(Decryption)	- 복호화 키를 이용하여 원래의 평문으로 변환시키는 과정
키 (Key)	- 암호화 알고리즘의 매개변수
암호 알고리즘 (Encryption Algorithm)	- 암호화와 복호화에 이용되는 알고리즘
암호 시스템(Cryptosystem)	- 암호화 기술과 복호화 기술의 통칭

암호화(Encryption)

□ 키(Key)의 형태에 따른 분류

구분	대칭키	비대칭키
개념도	대칭형 암호화 알고리즘(키가 동일) 	비 대칭형 암호화 알고리즘(키가 다름) 
대표 알고리즘	DES, SEED, AES	RSA, ECC
키의 관계	암호키 = 복호키	암호키 ≠ 복호키
키의 수	- 두 사람이 한 개의 비밀키를 공유	- 전송 당사자간에 각각 키쌍(Private Key, Public Key)를 공유
키의 종류	- 암호화 키 : Secret Key - 복호화 키 : Secret Key	- 암호화 키 : Public Key - 복호화 키 : Private Key

공개키(public key) 기법

1. 공개키(public key) 기법의 개요

□ 대표적인 공개키 기법



- 대표적인 공개키 기법에는 최초의 공개키 기법인 Diffie-Hellman 키 교환 알고리즘과 최초의 공개키 암호 시스템 RSA 암호시스템이 있음

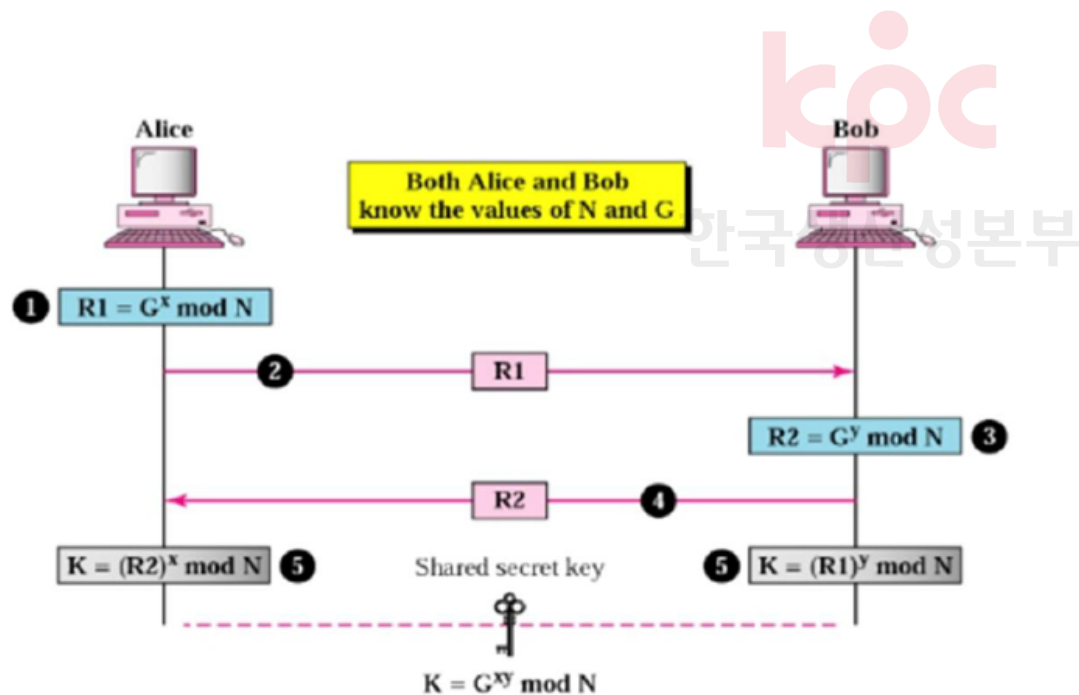
공개키(public key) 기법

2. Diffie-Hellman 공개키 암호 시스템

□ Diffie-Hellman 알고리즘 개요

- 1976년에 발표된 암호화되지 않은 통신망에서 비밀키를 공유할 수 있는 키 교환 방법
- 휘트필드 디피(Whitfield Diffie)와 마틴 헬먼(Martin Hellman)이 발명한 알고리즘

□ 동작방식



공개키(public key) 기법

절차	내용
소수 p , 정수 g 공유	- 엘리스가 소수 p , 그리고 1부터 $p-1$ 까지의 정수 g 를 선택하여 사전에 밥과 공유
정수 a 선택	- 엘리스가 정수 a 를 선택, 이 정수는 외부에 공개되지 않으며, 밥도 알 수 없음
엘리스 A 나머지 연산	- 엘리스가 $A = g^a \pmod{p}$, 즉 g^a 를 p 로 나눈 나머지를 계산
정수 b 선택 B 연산	- 밥이 정수 b 를 선택, $B = g^b \pmod{p}$, g^b 를 p 로 나눈 나머지를 계산
A, B 전송	- 엘리스와 밥이 서로에게 A 와 B 를 전송
비밀키 공유	- 엘리스가 $K_a = B^a \pmod{p}$, 밥이 $K_b = A^b \pmod{p}$ 를 계산

- 소수 p , 정수 g , A , B 값을 알더라도 B^a , A^b 의 a , b 를 모르면 비밀키를 알 수 없음

DES(Data Encryption Standard)

1. 블록 암호화 방식, DES의 개요

□ DES(Data Encryption Standard) 정의

- 56bit의 키를 이용하여 64bit의 평문 블록²을 64bit 암호문 블록으로 만드는 블록 암호방식의 미국표준(16 라운드 페이스텔 구조 사용)

※ 참고

DES의 키 비트 길이는 56 비트이다. 규격상으로는 DES의 키는 64 비트이지만, 7 비트마다 오류 검출을 위한 정보가 1 비트씩 들어가기 때문에 실질적으로 56 비트가 된다.

- 국립 표준 기술 연구소(NIST)에 의해 발표된 대칭키 블록 암호화 방식(파이스텔 암호 방식)

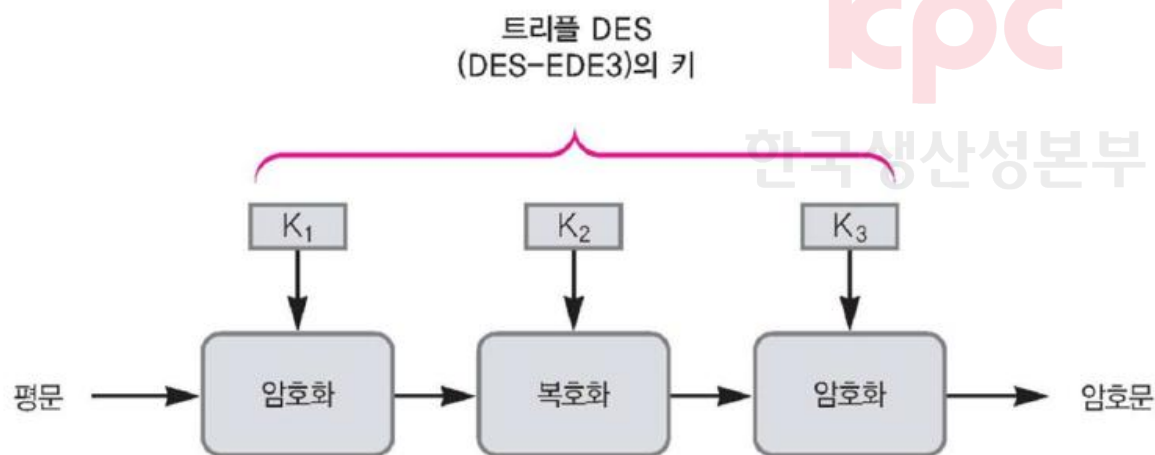
※ DES로 한번에 암호화할 수 있는 것은 64비트. 그것보다 긴 비트 길이의 평문을 암호화하기 위해서는 평문을 블록단위로 잘라낸 다음 DES를 이용해서 암호화 반복(mode, 모드 적용)

DES(Data Encryption Standard)

□ DES의 한계

- 최근 컴퓨터 연산 성능 향상으로 DES 알고리즘은 쉽게 해독 가능
- 보안성을 강화한 2-DES, 3-DES 사용을 권고
- DES의 한계점을 개선한 AES (Advance Encryption Standard)가 새로운 미국 표준

□ 3DES의 정의



- DES를 보완하기 위하여 DES를 3번 연속시킨 알고리즘
- DES는 key가 8byte, 3DES는 24byte 필요(DES의 키는 실질적으로 56비트 이므로, 트리플 DES의 키는 $56 \times 3 = 168$ 비트)

SPN(Substitution - Permutation Network)

1. SPN(Substitution-Permutation Network)의 개요

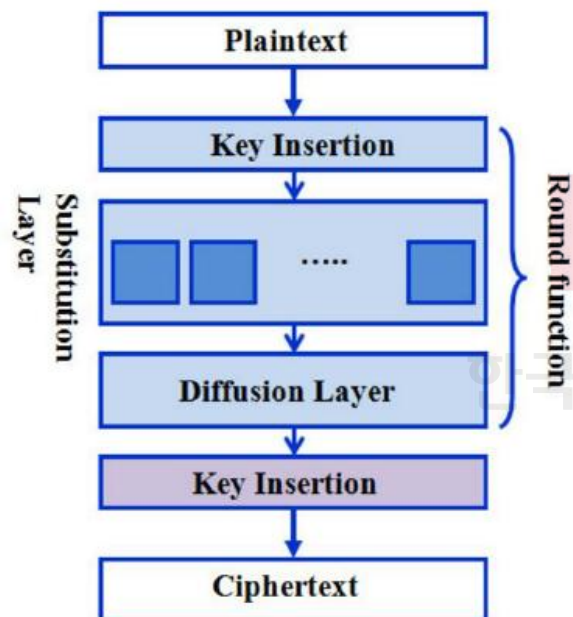
□ SPN(Substitution-Permutation Network)의 정의

- Substitution layer와 Permutation layer를 이용하여 confusion과 diffusion을 만족시키는 암호 알고리즘
- S-Box(대체 박스) 와 P-Box(치환 박스)를 이용한 구조로 많은 병렬성을 갖추고 있어 암호화, 복호화 알고리즘의 고속화가 요구되고, 최근의 컴퓨터 CPU 가 더 많은 병렬성을 지원하는 등의 현 추세에 부응하는 블록 암호 알고리즘의 한 형태

SPN(Substitution - Permutation Network)

2. SPN 구조

□ SPN 개념도



SPN(Substitution - Permutation Network)

□ SPN의 주요 함수 및 기능

구분	내용
subBytes()	- Substitution을 통한 Confusion 제공 - 16개의 독립된 바이트 단위로 변환을 수행 - Substitution-table을 통한 대치 알고리즘을 제공
ShiftRows()	- 행 단위 이동 수행 - 각 Row의 바이트 단위의 왼쪽 순환 이동 수행 - Permutation을 통한 Diffusion 제공 - 행 단위별 데이터 뒤섞음이 목적
MixColumns()	- 열 단위 연산 수행 - 각각의 열을 계산하여 새로운 값을 갖는 열을 출력 - 열 단위별 데이터 뒤섞음이 목적
AddRoundKey()	- 실제 암호화 과정 수행 - State의 각 바이트와 라운드 키의 XOR 연산 수행 - 라운드 키는 Key Expansion 스케줄링에 의해 제공

SPN(Substitution - Permutation Network)

3. AES 에서의 SPN 과정

□ Plaintext 의 State 변환

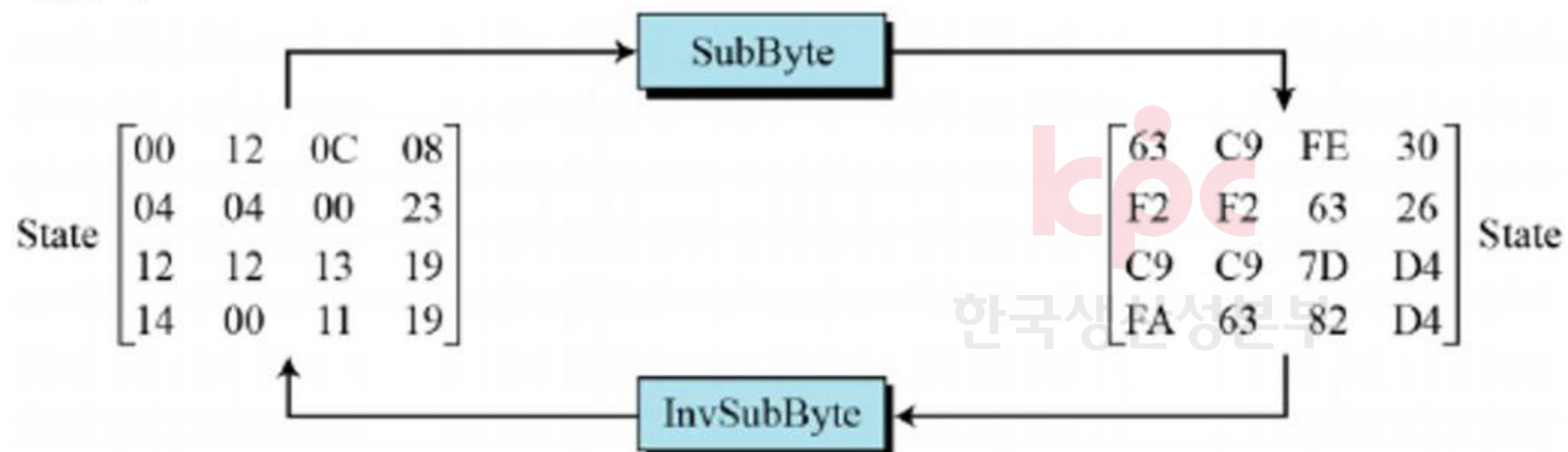
- 일반 텍스트의 16 진수 변환과 State 로의 변환
- 일반 텍스트 변환 예

Text	A E S U S E S A M A T R I X Z Z															
Hexadecimal	00 04 12 14 12 04 12 00 0C 00 13 11 08 23 19 19															
	00120C08 04040023 12121319 14001119 State															

SPN(Substitution - Permutation Network)

□ SubBytes()

- Substitution 테이블을 통해 변환
- 변환 예



SPN(Substitution - Permutation Network)

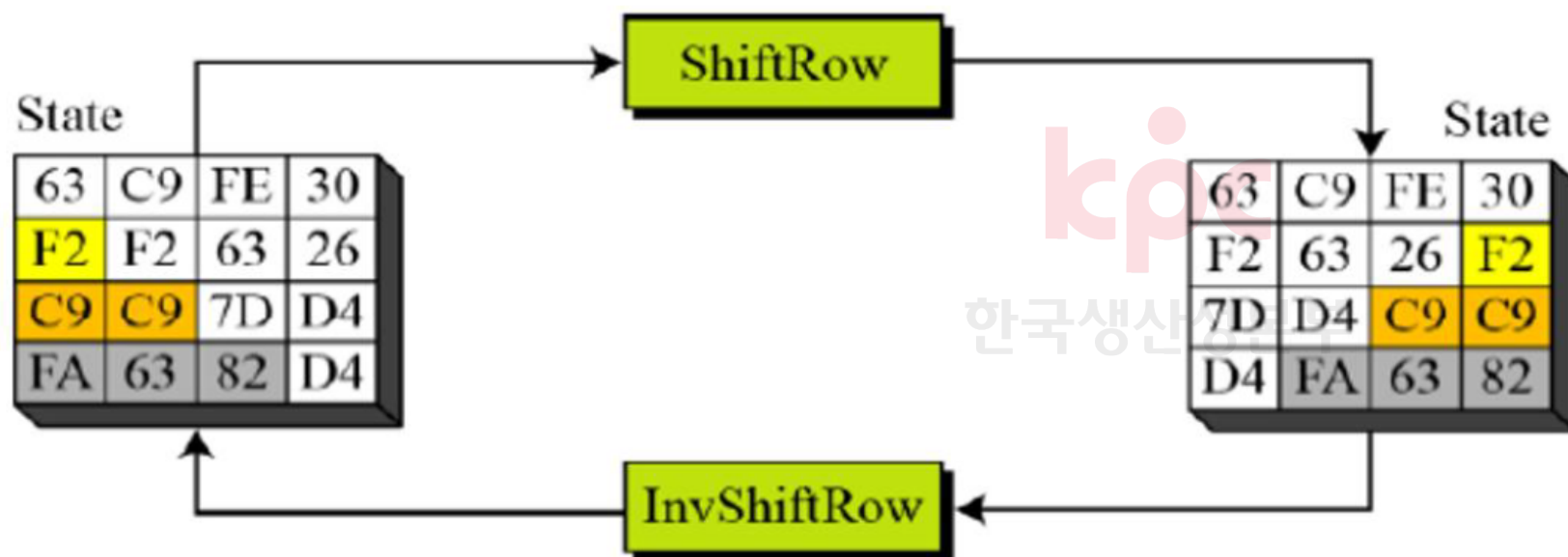
- Substitution 테이블 (S-Box)

		y															
		0	1	2	3	4	5	6	7	8	9	a	b	c	d	e	f
x	0	63	7c	77	7b	f2	6b	6f	c5	30	01	67	2b	fe	d7	ab	76
	1	ca	82	c9	7d	fa	59	47	f0	ad	d4	a2	af	9c	a4	72	c0
	2	b7	fd	93	26	36	3f	f7	cc	34	a5	e5	f1	71	d8	31	15
	3	04	c7	23	c3	18	96	05	9a	07	12	80	e2	eb	27	b2	75
	4	09	83	2c	1a	1b	6e	5a	a0	52	3b	d6	b3	29	e3	2f	84
	5	53	d1	00	ed	20	fc	b1	5b	6a	cb	be	39	4a	4c	58	cf
	6	d0	ef	aa	fb	43	4d	33	85	45	f9	02	7f	50	3c	9f	a8
	7	51	a3	40	8f	92	9d	38	f5	bc	b6	da	21	10	ff	f3	d2
	8	cd	0c	13	ec	5f	97	44	17	c4	a7	7e	3d	64	5d	19	73
	9	60	81	4f	dc	22	2a	90	88	46	ee	b8	14	de	5e	0b	db
	a	e0	32	3a	0a	49	06	24	5c	c2	d3	ac	62	91	95	e4	79
	b	e7	c8	37	6d	8d	d5	4e	a9	6c	56	f4	ea	65	7a	ae	08
	c	ba	78	25	2e	1c	a6	b4	c6	e8	dd	74	1f	4b	bd	8b	8a
	d	70	3e	b5	66	48	03	f6	0e	61	35	57	b9	86	c1	1d	9e
	e	e1	f8	98	11	69	d9	8e	94	9b	1e	87	e9	ce	55	28	df
	f	8c	a1	89	0d	bf	e6	42	68	41	99	2d	0f	b0	54	bb	16

SPN(Substitution - Permutation Network)

□ ShiftRows()

- State 의 0 번째 행은 건너뛰고 1 번째 행부터 1 바이트씩 왼쪽 순환 이동
- ShiftRows() 변환 예



SPN(Substitution - Permutation Network)

□ MixColumns()

- 행렬 곱셈을 이용하여 바이트들을 뒤섞는 과정

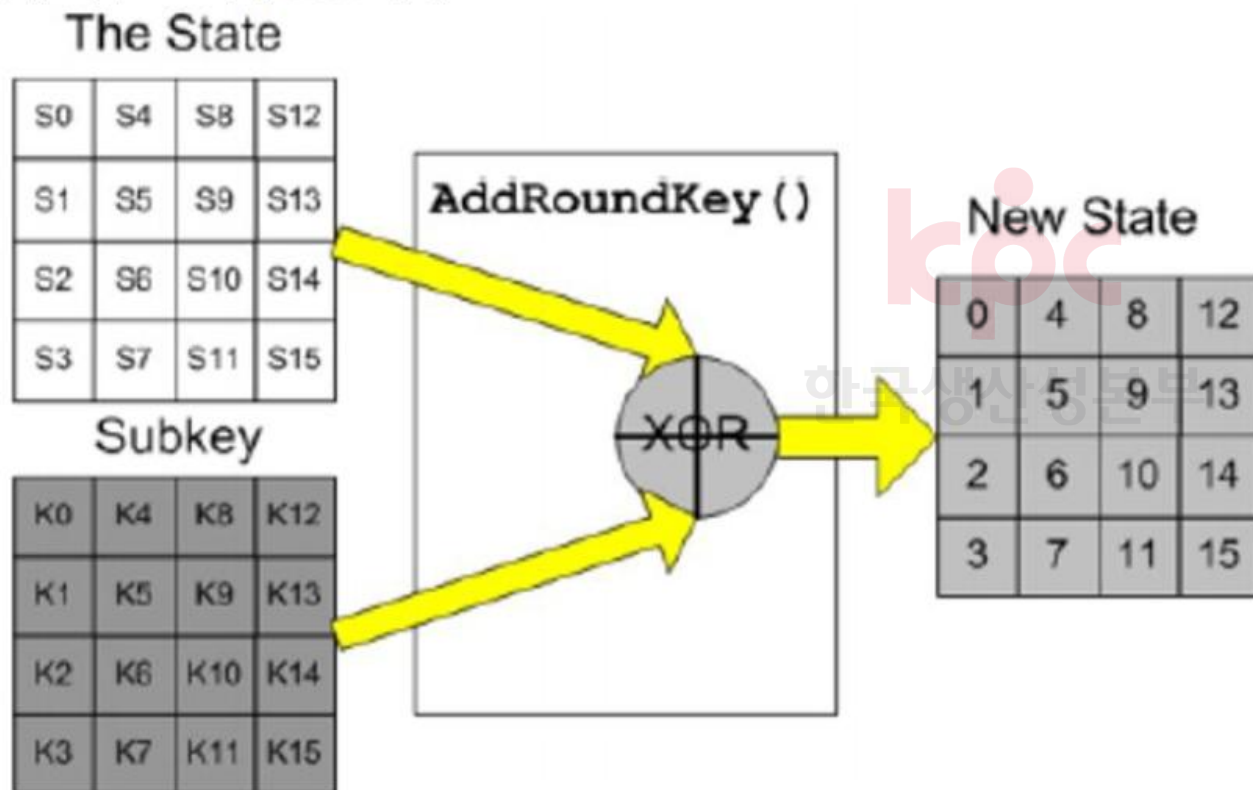
$$\begin{bmatrix} ax + by + cz + dt \\ ex + fy + gz + ht \\ ix + jy + kz + lt \\ mx + ny + oz + pt \end{bmatrix} = \begin{bmatrix} a & b & c & d \\ e & f & g & h \\ i & j & k & l \\ m & n & o & p \end{bmatrix} \times \begin{bmatrix} x \\ y \\ z \\ t \end{bmatrix}$$

New matrix Constant matrix Old matrix

SPN(Substitution - Permutation Network)

□ AddRoundKey()

- State 행렬에 라운드 키와 XOR 수행



AES(Advanced Encryption Standard)

1. AES의 개요

□ AES(Advanced Encryption Standard)의 정의

- Substitute bytes, Shift rows, Mix columns, Add round key 단계를 이용하여 높은 안정성과 속도로 데이터를 암호화하는 알고리즘 방식
- 128비트 블록과 길이가 128, 192 또는 256 비트인 키를 사용하는 대칭 블록 암호 알고리즘



- AES 암호화 방식은 기존의 DES 암호화 방식의 안정성 문제를 해결하기 위해 공보를 통해 선정됨

AES(Advanced Encryption Standard)

2. AES 암호화 방식의 특징

□ AES 암호화 방식의 기술적 특징

기술적 특징	내용
ROUND 구조	- 동일한 알고리즘을 반복하여 실행, 10/12/14회
대칭성	- 암호화/복호화 방법이 각각에 대하여 대칭적 구조
가변키	- 128/192/256 bit 가변키
블록 암호화	- 블록 단위의 암/복호화 수행

□ AES 암호화 방식의 배경적 특징

배경적 특징	내용
DES 대체	- DES 암호화 알고리즘의 안정성 문제로 탄생
공모	- 알고리즘에 대한 공모를 통해 채택
NIST 주도	- NIST 주도로 기밀문서에 대한 암호화 표준 지정

해쉬함수(Hash function)

1. 해쉬함수의 개요

□ 해쉬함수(Hash function)의 정의

- 임의의 길이를 가지고 있는 메시지를 받아들여 고정된 길이의 출력 값으로 바꾸어주는 함수
- 해쉬함수를 사용하면 같은 해시 값을 갖는 두 개의 다른 입력 메시지를 찾아내기란 불가능하므로 하나의 해시 값을 가지고 원래의 입력된 메시지를 예측 불가
- 데이터 전송 도중 데이터가 변조 여부 확인이 가능해 전자서명 등에 유용하게 사용
- 해쉬함수는 단방향으로 일정한 크기의 MD(Message Digest)를 생성함

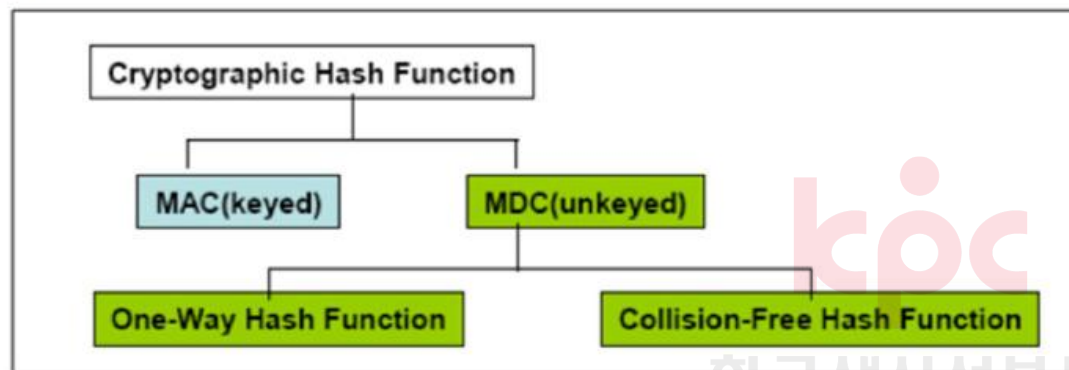
□ 해쉬함수의 특징

구분	내용
특징	고속성, 압축성, 일방향성, 충돌내성
종류	MD5, SHA-1, SHA-2 등
용도	데이터 무결성 검사, 전자서명, 인증, 난수 생성기

해시함수(Hash function)

2. 해시함수의 분류

□ 해시함수의 분류



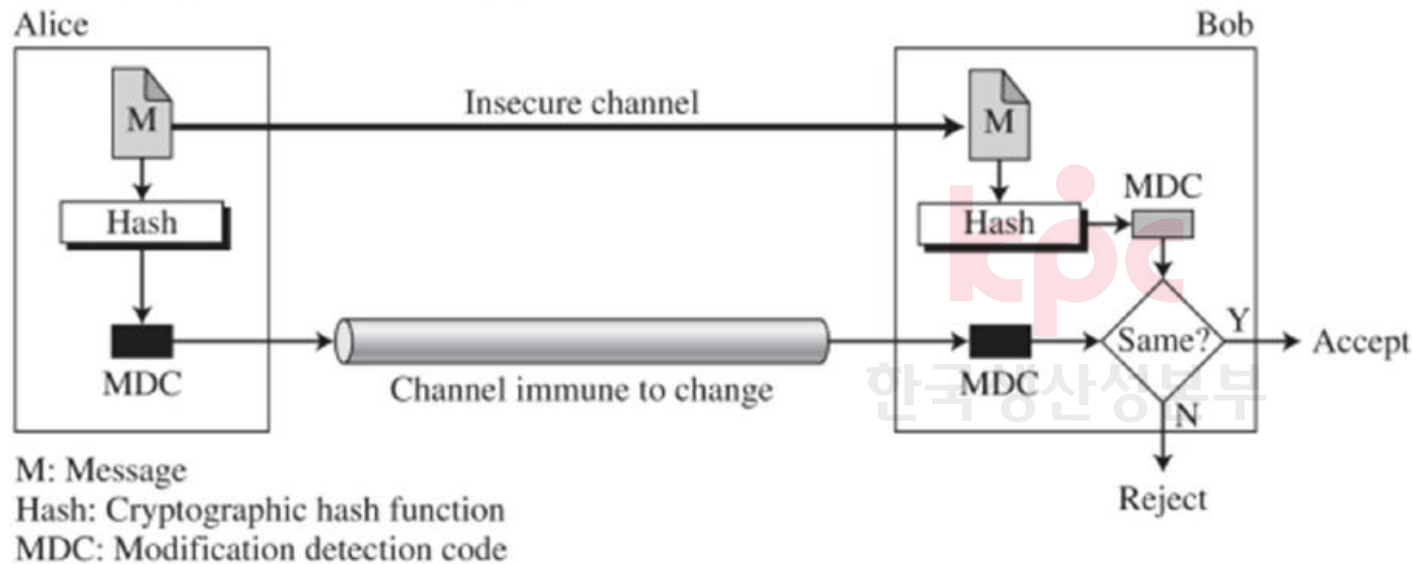
$$m \quad \text{[key]} \longrightarrow \text{MAC} = h(k, m)$$

$$m \quad \text{[key]} \longrightarrow \text{MDC} = h(m)$$

해쉬함수(Hash function)

□ MDC(Modification Detection Code)

- 메시지의 무결성을 보장하는 다이제스트

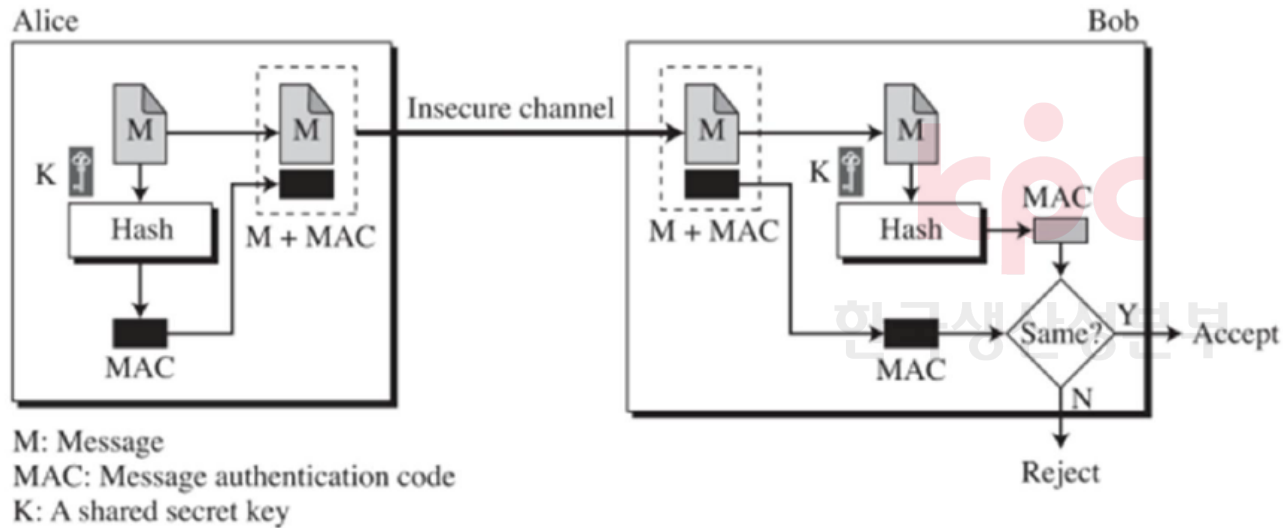


- 송신자는 원본 메시지 M 을 안전하지 않은 채널(Insecure channel)로 수신자에게 전송
- $H(M)$ 을 통해 생성된 MDC를 안전한 채널(channel immune to change)로 전송
- 이를 수신한 수신자는 송신자가 MDC를 생성한 같은 알고리즘으로 M 에 대해 MDC를 생성하고, 이를 비교하여 메시지 M 의 무결성 확보

해쉬함수(Hash function)

□ MAC(Modification Authentication Code)

- 메시지의 무결성과 전송자를 증명하는 코드로써, 데이터 출처를 인증하는 코드
- MAC가 MDC와 다른점은 송/수신자 양자만 공유하고 있는 비밀키를 사용한다는 것



- 원본 메시지 M 을 비밀키 K 와 병합하여 해쉬 수행
- $H(M)$ 은 $H(K|M)$ 으로 변경되어서 MAC를 생성
- MDC와는 다르게 MAC은 안전하지 않은 채널을 통해 전송
- 수신자는 전송받은 데이터에서 MAC을 추출하고, 메시지 M 과 송신자의 비밀키 K 를 사용하여 MAC' 을 생성
- 추출한 MAC와 생성한 MAC' 를 비교하여 메시지에 대한 인증 검증

해시함수(Hash function)

3. 해시함수의 3 가지 안전성

□ 3 가지 안전성 성질들간의 관계



□ 해시함수 저항성

저항성	내용
역상 저항성 (Preimage Resistance)	- y 가 주어지고, $h(x) = y$ 인 x 를 찾는 것이 어려움
제 2 역상 저항성 (2 nd -Preimage Resistance)	- $h(x) = y$ 인 x 와 y 가 주어지고, $h(x') = y$ 인 x' 을 찾는 것이 어려움
충돌 저항성 (Collision Resistance)	- $h(x) = h(x')$ 인 x, x' 을 찾는 것이 어려움

양자암호통신

1. 양자암호통신의 개요

□ 양자암호통신(Quantum Cryptography Communication)의 정의

- 양자(특히, 광자)의 특성을 이용하여 멀리 떨어져 있는 사람이 통신 상에서 암호 비밀키를 안전하게 나누어 갖고 암호 통신을 수행하는 기술
- 양자역학 기반의 양자 정보체계를 활용하여 다양한 암호적 기능들을 구현하여 안전성을 확보하여 양자 중첩이나 불확정성, 비복제성 등의 다양한 물리 현상을 이용하는 암호 통신 기술

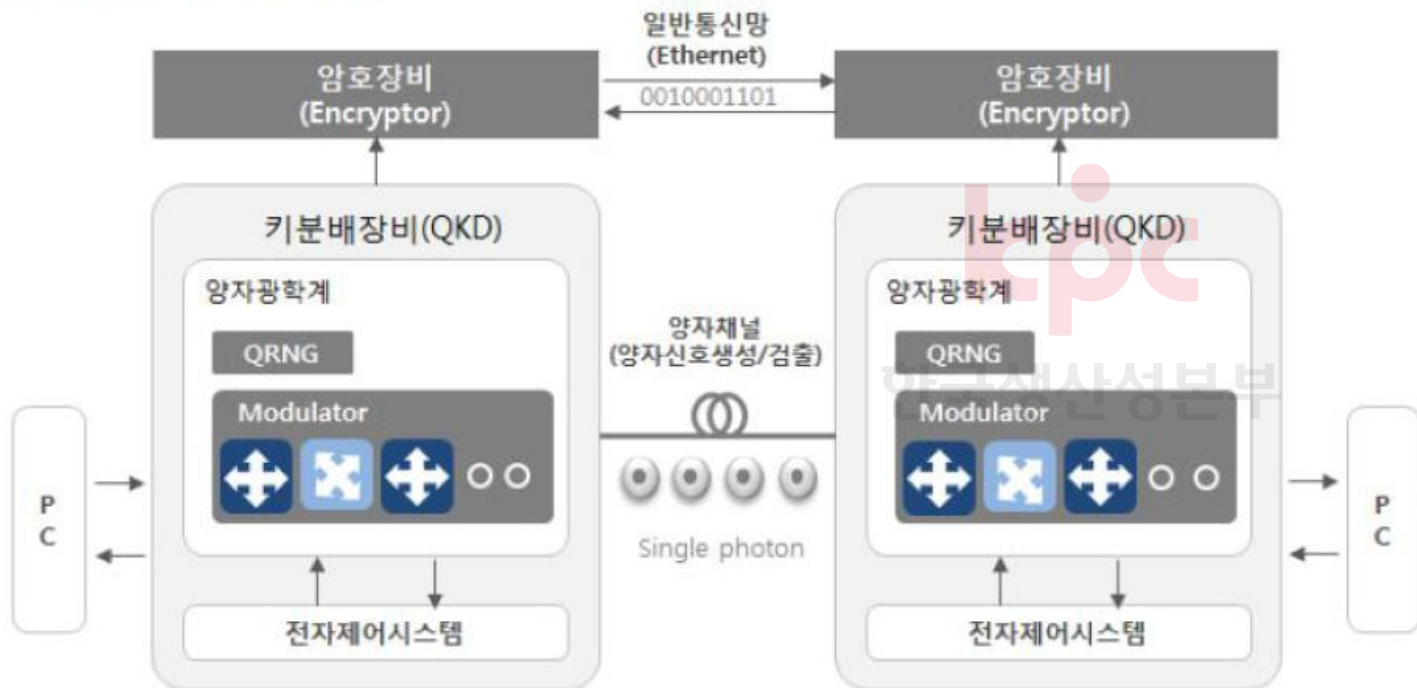
□ 양자암호통신의 특징

특징	설명
양자중첩	- 0과 1의 상태가 동시에 존재하는 것으로, 여러 상태가 확률적으로 하나의 양자에 동시에 존재하고 측정하기 전까지 정확한 양자 상태를 알 수 없음
양자얽힘	- 둘 이상의 양자가 가지는 상관관계로 두 양자가 서로 멀리 떨어져 있어도 존재하는 특성
불확정성	- 서로 다른 물리량이 동시에 정확하게 측정이 불가능한 특성으로 여러 상태를 동시에 가지고 있고 동시에 측정할 수 없어 복제 불가능

양자암호통신

2. 양자암호통신 시스템 구성도 및 구성요소

□ 양자암호통신 시스템 구성도



양자암호통신

□ 양자암호통신 시스템 구성요소

구성요소	설명
양자키분배 전송시스템(QKD)	- 광자가 자신의 양자 상태를 바꾸지 않고 가로채어질 수 없다는 양자물리학의 법칙에 근거하여 양자키 생성 및 전송 분배, 오류정정, 프라이버시 증폭 등을 수행
	- 양자키 분배 프로토콜 : BB84 프로토콜 - 양자키 분배 시스템 : one way 방식, Plug and Play 방식 - QKD 시스템 구성 1) 양자광학부분 : 양자광원과 간섭계, 변조기, 검출기로 구성 2) 전자제어부 : 구동회로부, 신호처리부, 외부 인터페이스, 제어회로부
양자데이터 암호장비(QED)	- 신호의 증폭 불가와 같은 양자 역학의 장애를 극복하고 양자소음을 이용하여 도청을 방해하는 양자 암호 기법 사용 - 일반적으로 VPN(Virtual Private Network) 장비로 응용
양자통신네트워크	- 300가지 이상의 연속적 키 변화를 통해 1kbit 암호화 키의 갱신이 3초마다 이루어지면서 155Mbps의 암호화된 SONET 데이터 망으로 구성

양자내성암호(Post-Quantum Cryptography)

1. 양자내성암호의 개요

□ 양자내성암호의 정의

- 양자 컴퓨터의 보안 위협에 대응할 수 있는 암호 기술로, 양자 컴퓨터의 연산능력으로도 풀 수 없는 수학적 난제를 활용한 암호화 기술

□ 양자 알고리즘의 특징과 안전성

알고리즘	특징	암호	영향
Shor	- 인수분해 문제 해결 속도 감소	- 공개키	- 더 이상 안전하지 않음
Grover	- 정렬되지 않은 데이터베이스의 원소를 검색하는 속도 향상	- 대칭키	- 키 사이즈 증가 필요
		- 해시	- 암호 알고리즘의 출력 길이 증가 필요

양자내성암호(Post-Quantum Cryptography)

2. 양자내성암호 유형

알고리즘	특징	암호
다변수기반 (Multivariate-based) 암호	- 안전성과 연산 효율성을 위해 주로 이차함수를 사용하며, 암호 복호화가 다항식의 계산이기 때문에 전력 분석의 부채널 공격에 대해 안전함 - 키 사이즈가 크기 때문에 주로 서명 기법에 이용됨	- HFE, ZHFE - UOV(Unbalanced Oil and Vinegar) - Rainbow
코드기반(Codebased) 암호	- 행렬연산이라 연산속도가 빠름 - 복호화가 암호화에 비해 연산 속도가 느리고 키 사이즈가 큼 - 메시지에 의도적으로 오류를 주입하여 오류를 알고 있는 사용자만 메시지를 복원할 수 있게 만드는 방식	- McEliece - Modern McEliece - Niederreiter - MCPC-McEliece - Wild McEliece - McBits

양자내성암호(Post-Quantum Cryptography)

격자기반(Latticebased) 암호	- LWE(Learning with Errors)등의 문제를 푸는 어려움을 기반으로 설계 됨 - 암호 · 복호화, 전자서명, 동형암호, 함수암호, IBE(ID-based Encryption) 등 다양한 응용분야에 서 연구 진행	- NTRU, SS-NTRU - BLISS - New Hope - NTRU Prime - LWE-Frodo
아이소제니기반(Isogeny-based) 암호	- 주어진 두 타원 곡선(elliptic curve)들 사이의 아이소제니 관계를 구하는 문제를 이용한 암호 알고리즘	- Diffie-Hellman like protocol - SIDH(Supersingular Isogeny Deffie-Hellman)
해시기반(Hashbased) 전자서명	- 암호학적 해시함수를 이용하여 전자서명 스킴을 구성하며 사용되는 해시함수의 충돌 저항성에 의해 안전성을 보장함 - 양자컴퓨팅 환경에서도 해시함수는 출력의 길이만 늘리면 안정성을 보장할 수 있음	- W-OTS - W-OTS+ - HORS - SPHINCS

디지털 보안

3. 네트워크 보안

kpc

한국생산성본부

KPC 정보관리기술사 기본반



3. 네트워크 보안

방화벽(Firewall)	43
IDS(Intrusion Detection System)	45
IPS(Intrusion Prevention System)	48
SSL(Secure Socket Layer)	50
망분리	51

방화벽(Firewall)

1. 외부의 침입을 차단하기 위한 전방위 보안시스템, 방화벽의 개요

□ 방화벽(Firewall)의 정의

- 외부로부터 불법침입과 내부의 불법정보 유출을 방지하고, 내/외부 네트워크의 상호간 영향을 차단하기 위한 보안 시스템
- 네트워크를 통해 흐르는 Packet(데이터 단위)을 미리 정해놓은 구성에 따라 차단하거나 전달하는 기능을 수행하는 소프트웨어 또는 하드웨어를 의미함

□ 방화벽 도입의 필요성

- 네트워크를 필터링(filtering)함으로써 서브넷 상에 있는 호스트의 위험을 감소.
- 외부 네트워크에서 내부 네트워크에 있는 호스트로 접속하고자 할 때 원하지 않는 액세스 차단.
- 네트워크 액세스 제어 정책에 대한 구현을 제공하여 사용자와 서비스에 대한 액세스를 제어.

방화벽(Firewall)

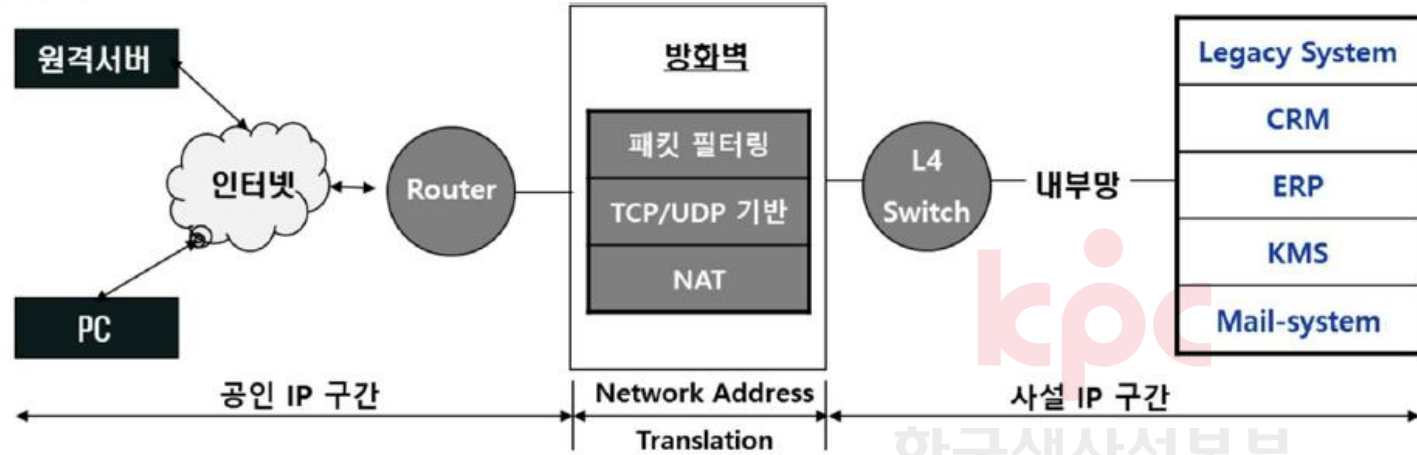
2. 방화벽 시스템의 보안 기능 및 구성도

□ 보안 기능

기 능	설 명
접근제어	- Packet Filtering; 특정 송신원의 주소 혹은 발신원 주소 등을 가진 패킷 통과 제한 기능 - 송수신자의 IP 주소, TCP, UDP의 포트번호를 바탕으로 패킷 필터링 - 방화벽이 지나는 모든 패킷을 정의된 보안 정책에 의해 막음
사용자 인증	- 트래픽에 대한 사용자의 신분을 증명하는 기능
감사 및 로그	- 트래픽에 대한 접속 정보 기록 - 네트워크 사용에 따른 유용한 통계 정보
프록시 기능	- Application 계층에 대한 필터링 기능(OSI 7 Layer) - 프록시 서버 : 프록시 서버는 네트워크 IP 주소를 대체하며, 실제 IP 주소를 인터넷상 에서 효과적으로 숨겨줌. 프록시 서버의 종류에는 웹 프록시, 회선/애플리케이션 수준 게이트웨이 등이 있음 - 클라이언트의 서비스 요청을 받아 보안정책에 따라 수행하는 서버 - 서비스 요청을 전달하고 실행 결과를 수신하여 사용자에게 전달(프락시 서버)

방화벽(Firewall)

□ 방화벽 구성도



- 외부 망과 내부 망의 상호 간 필터링 및 네트워크 주소 변환 기능을 제공하는 시스템 구성

방화벽(Firewall)

□ 방화벽의 한계

문제점	내용
침입 알람기능	- 침입발생 시, 사용자에게 알람 기능없음(Log기록 확인) - DoS나 DDoS공격에 취약
백도어	- 우회 경로를 통한 백도어 생성과 침입에 대해 방어안됨 - 정상적인 포트를 통해 들어오는 공격은 막을 수 없음(IRC)
내부 사용자에게 의한 보안침해	- 악의적인 내부 사용자에게 대한 보안 침해 방어 못함
다이얼 모뎀	- 외부네트워크로부터 내부 네트워크로 비 인가된 다이얼모뎀접근 방어 못함 - 1차적인 네트워크 침입 차단 역할만 수행
성능	- 네트워크의 성능이 느려질 수 있음
압축파일	- 파일압축, 암호화, 인코딩에 대한 방어 대책이 없음

IDS(Intrusion Detection System)

1. 실시간 침입탐지시스템, IDS의 개요

□ 침입탐지시스템(Intrusion Detect System)의 정의

- 비인가된 사용자가 자원의 무결성(integrity), 기밀성(confidentiality), 가용성(availability)을 저해하는 일련의 행동들과 보안 정책을 위반하는 행위, 즉 침입(Intrusion)을 실시간으로 탐지하는 시스템

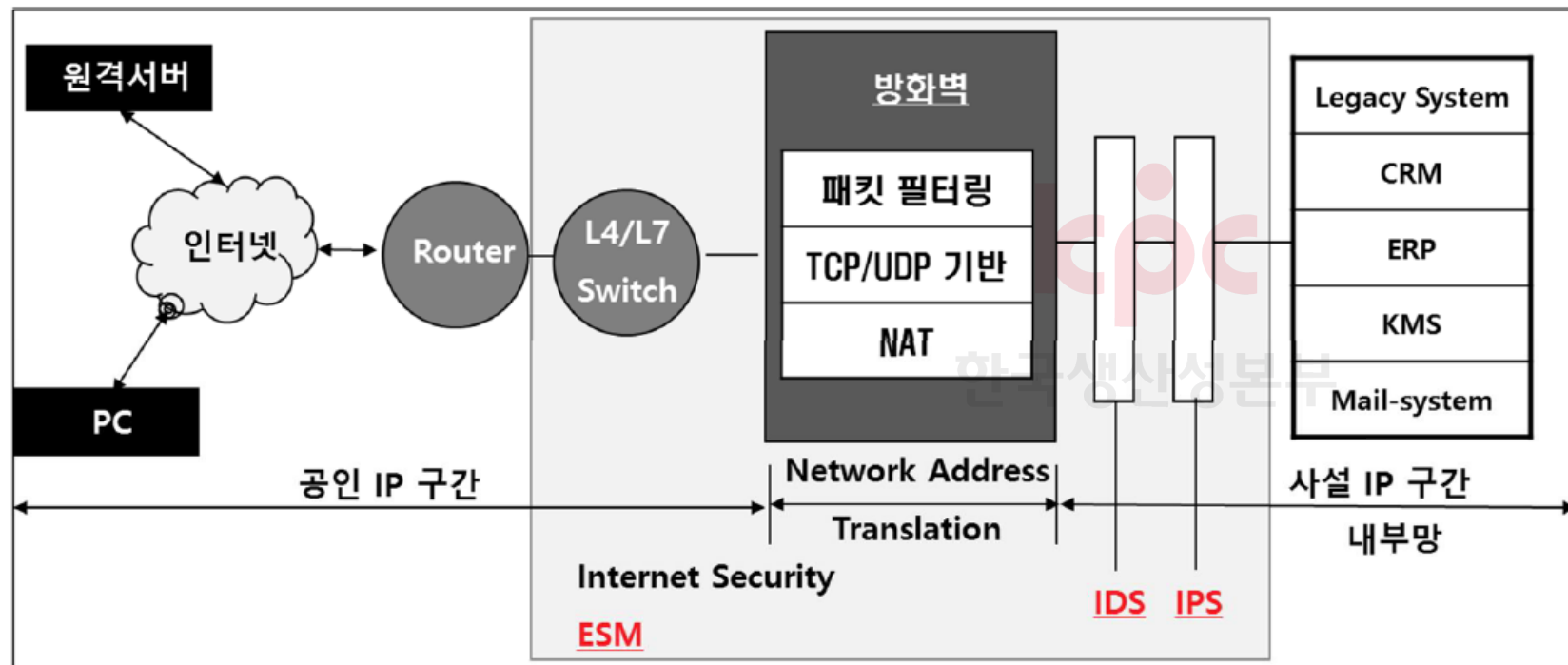
□ 침입탐지시스템의 필요성

- 외부침입자뿐만 아니라 내부 사용자의 불법적인 오남용 행위에 대처하는 방안이 필요함
- 침입차단시스템(Firewall)이 해킹 당했을 때의 피해 최소화 필요 및 방화벽 문제점을 보완
- 새로운 해킹관련 기술에 대한 지능적인 방지 시스템 필요

IDS(Intrusion Detection System)

2. 침입탐지시스템의 구성

□ IDS 및 IPS의 일반적 위치



IDS(Intrusion Detection System)

□ 침입탐지 시스템의 구성요소

구성요소	설명
정보 수집기	- 호스트나 네트워크로부터 분석 자료 수집
정보 분석기	- 시스템 설정과 패턴DB의 설정에 따라 정보 분석
로그 저장소	- 분석된 결과 저장
이벤트 보고기	- 로그 저장소의 분석결과를 해당 관리자에게 보고
패턴 생성기	- 침입 분석 자료를 통해 패턴을 생성
패턴 DB	- 패턴 생성기에 의해 생성된 패턴의 저장 관리

□ IDS의 주요 기능

주요기능	설명
경보 기능	- 경보, 이메일 발송, SNMP Trap 발송 등으로 통보
세션 차단 기능	- 의심스러운 행위 감지 시에 해당 세션 차단
실시간 탐지	- 시스템이나 네트워크를 모니터링하며 실시간 침입 탐지 기능
Reporting	- 통계적 분석 및 Reporting 기능

IDS(Intrusion Detection System)

□ 침입탐지시스템의 한계

- False Positive(거짓 탐지율); 침입이 아닌 네트워크 통신을 침입으로 탐지하는 행위
- False Negative(탐지실패율; Miss Detection); 침입인 통신을 침입이 아닌 행위로 판단
- 주로 침입을 탐지하는 기능으로 적극적인 대응 방법 없음

□ 침입탐지시스템의 전망

- 네트워크 기반 침입탐지시스템은 실시간 패킷분석을 위한 처리 능력과 저장의 한계를 극복
- 침입탐지시스템은 침입 이후에 침입 사실을 알게 되며 침입대응을 위해 ESM을 통해 Firewall과 연동되거나 보안관제가 필요함.
- 최근에는 침입과 동시에 자동적으로 차단을 수행하는 침입차단시스템(IPS)이 연동.

IPS(Intrusion Prevention System)

1. 침입탐지와 실시간 방어를 위한 솔루션, IPS 개요

□ 침입방지 시스템(Intrusion Prevention System)의 정의

- 침입탐지시스템의 오판(False Positive)와 미탐(Miss Detection)의 문제 해결을 위해 등장한 정보시스템 네트워크에서의 침입탐지와 실시간 방어가 가능한 보안 솔루션

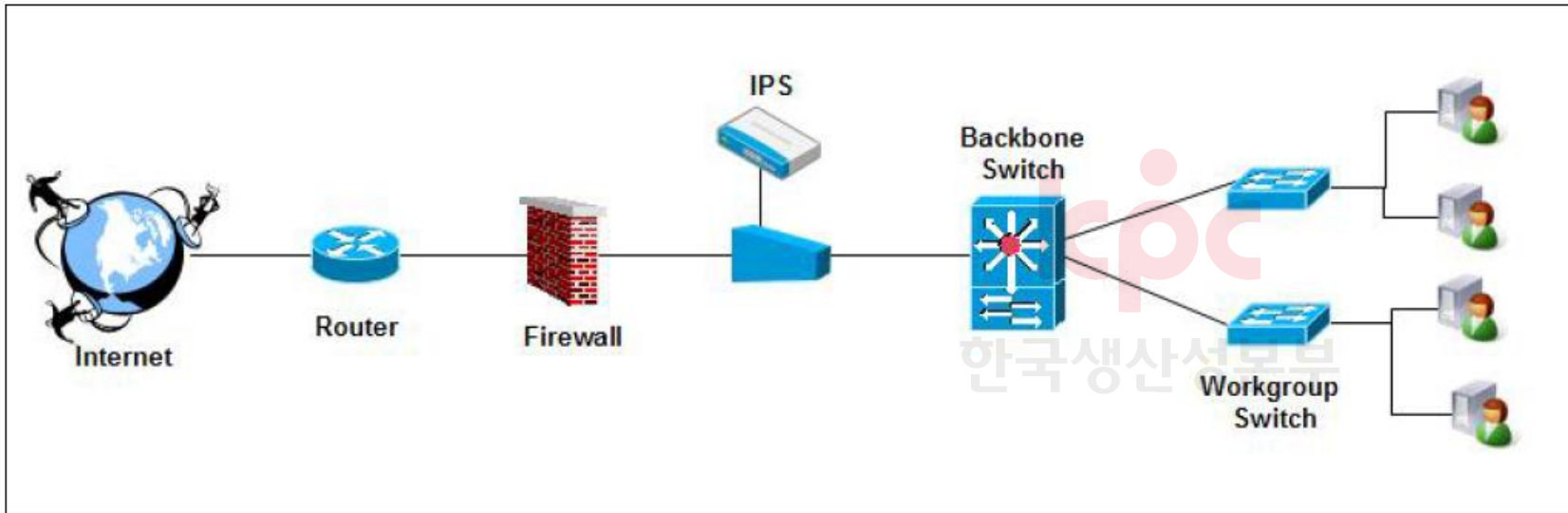
□ IPS의 특징

- 침입 및 바이러스 감염 등 각 상황에 맞는 실시간 자동 대응 시스템
- 광대역 통신망 패킷을 실시간 분석 및 알려지지 않은 공격을 탐지 (바이러스, 해킹 등)
- 단순 미러링이 아닌 네트워크 트래픽과 동일선상에 위치함으로써 오탐지율 감소
- 패킷 기반 탐지 이외에 세션 기반 탐지 가능

IPS(Intrusion Prevention System)

2. IPS 구성 및 이상징후 탐지기법

□ IPS의 구성



- IPS는 방화벽 후방에 인라인 형태로써 트래픽에 대한 모든 세션관리가 가능하게 구성됨
- 방화벽에서 DMZ를 구성시, DMZ 구간 링크에 대해서도 추가적으로 인라인으로 구성함
- 일반적으로 IPS로 인한 장애를 방지하기 위해서 고가용성 구조로써 구성함

IPS(Intrusion Prevention System)

□ IPS의 이상징후 탐지 기법

탐지기법	설명	사례
Protocol Anomaly	- 패킷별 프로토콜 표준 부합여부 점검 - 비정상 프로토콜과 악성코드 탐지와 차단	- 웹 트래픽의 비표준 포트 접속 요청
Application Anomaly	- 어플리케이션의 비정상 동작 및 행위탐지 - 어플리케이션 패킷 악성코드 탐지와 차단	- 사용자 패스워드 필드에 바이너리 셸코드 존재
Statistical Anomaly	- 트래픽에 대한 정상 및 비정상 여부 분석 - 대량의 비정상 패킷 발생 탐지와 차단	- TCP 트래픽 대비 과도한 UDP 트래픽 생성 - 임계치 기준 새로운 트래픽/어플리케이션 증가
Unified Anomaly	- Protocol anomaly와 Statistical Anomaly 혼용 - Application Anomaly와 Statistical Anomaly 혼용	- 표준 포트 이용 백도어와 P2P 어플리케이션 동작 - 어플리케이션을 통한 비정상적 크기의 패킷 송수신

IPS(Intrusion Prevention System)

4. IPS 와 IDS 의 비교

구분	IDS	IPS
성격	- Positive & Reactive 탐지 - 패턴 등록 후 반응	- Active & Pro-Active - 공격전 사전 차단
목적	- 침입 여부 탐지	- 침입 방지 목적 - 침입 탐지 후 적극적 대응
Packet 공격	- 첫번째 패킷 공격 방어 어려움	- 방지 가능
Zero-day Attack	- 방어하기 어려움	- 일부 가능
분석방법	- 시그니처 DB기반 패턴 매칭 방법 - 알려진 공격 패턴 탐지	- 시스템 Call에 대해 정책, Rule DB기반 - 비정상 행위 방지
대응 방법	- 관리자에게 경고 - ESM 통해 Firewall Rule Set 변경	- 알려지지 않은 공격탐지 - 자원 접근 차단

SSL(Secure Socket Layer)

1. 인터넷을 통한 암호 메시지의 전송 수단, SSL(Secure Socket Layer)의 개요

□ SSL (Secure Socket Layer) 의 정의

- TCP/IP상에서 웹 브라우저와 웹 서버간에 데이터를 안전하게 주고 받기 위하여 전자상거래 등의 보안을 위해 개발된 암호화 통신 프로토콜
- TLS(Transport Layer Security)로 표준화 되었으며, 기본적으로 인증(Authentication), 암호화(Encryption), 무결성(Integrity)을 보장(1994년 Netscape사에 의해서 개발)

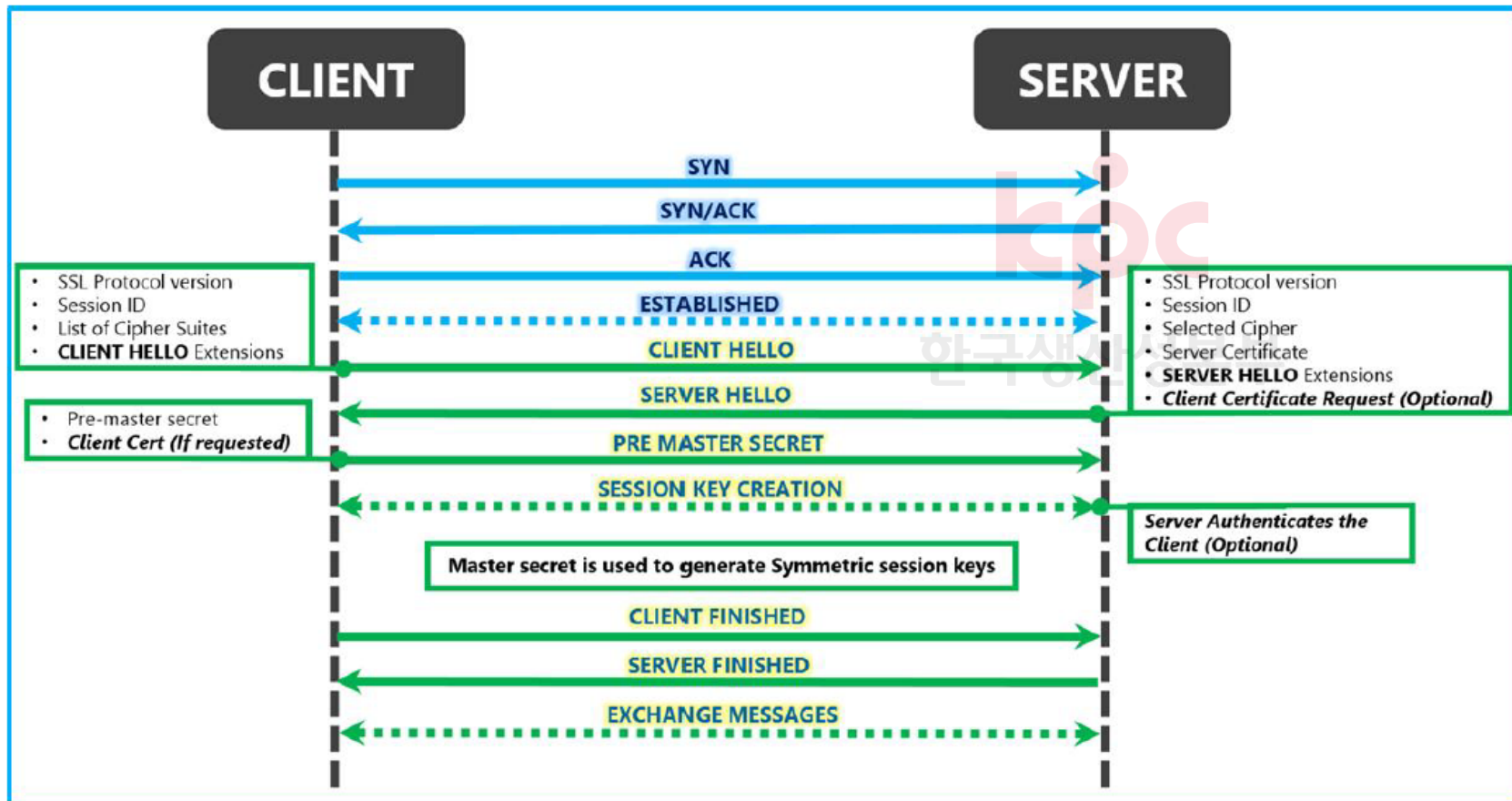
□ SSL 의 특징

구분	설명
공개키 기반 인증방식	- RSA방식과 X.509 v3인증서를 사용함
3가지 인증 모드 지원	- 익명 인증 모드(An, Anonymous), 서버 인증 모드(SA, Server Authentication), 클라이언트-서버인증 모드(MA, Mutual authentication)
연결주소	- https:// 로 시작하는 연결주소
지정포트	- 443번 포트, OSI 7 Layer에서 전송 ~ 응용계층에서 동작

SSL(Secure Socket Layer)

2. SSL의 동작 원리

□ SSL 동작 원리



망분리

1. 망분리의 개요

□ 망분리의 정의

- 내부 업무 영역과 외부 인터넷 영역을 분리하여, 인터넷 영역에서 내부 시스템 접근을 차단하여 개인정보 및 중요 데이터를 외부로 유출하는 것을 차단하는 네트워크 구성 방식

등장배경 및 근거

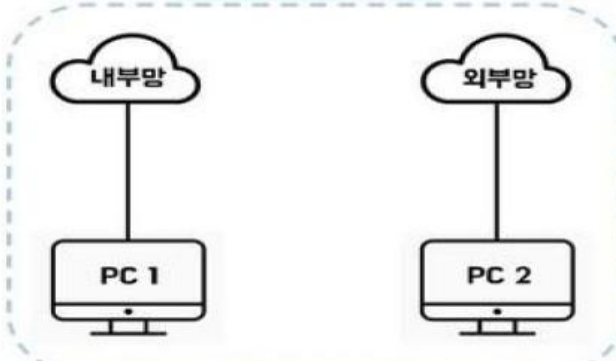
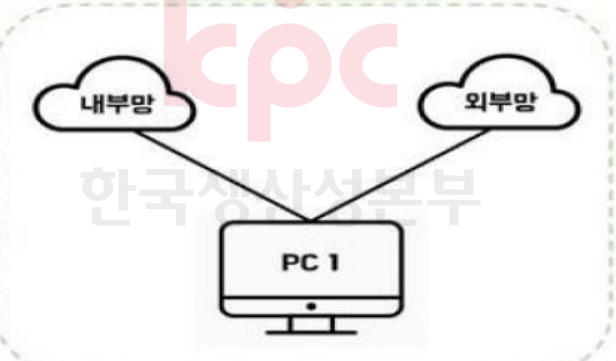
- 2006년 국정원
국가정보보안기본지침 의거,
공공기관 망분리 명시
- 2011년 금융권 전산 장애 사태
- 2012년 주요 언론 및 기업 전산망
마비
- 2013년 전자금융감독규정 해킹 등
방지대책 시행, 금융권 망분리
의무화
- 개인정보의 안전성 확보조치 기준
개정에 의한 모든 개인정보처리자
망분리 의무대상 적용

주요기술

- 별도 회선 여부에 따른 물리적 /
논리적 망분리 유형
- 논리적 망분리 구현 위한 SBC,
CBC 등 가상화 기술 활용
- 분리된 망간의 자료 연계를 통한
망연계 기술 활용, 업무 불편
일부분 해소
- KVM 스위치 등 사용 편의 위한
물리적 기기 전환 장치 이용
- 단말기, 통신, 데이터 기반
보안관리, 패치관리, 접근제어 등
원칙 준수 필요

망분리

□ 망분리의 유형

구분	물리적 망분리	논리적 망분리
정의	2 개 이상의 회선 및 단말기 또는 HW 를 사용해 물리적으로 구분하는 분리방식	가상화 기술을 사용하여 논리적으로 분리된 네트워크를 사용하는 분리방식
구성도	<물리적 망분리> 	<논리적 망분리> 
구현방법	- 2 대 PC 이용, 네트워크 전환장치 이용	- 서버 가상화, PC 가상화
구성요소	- 네트워크 전환장치, 별도회선 사용	- VDI, SBC, CBC, OS 공유
장점	- 인터넷 망과 업무망간 경로 물리적 차단 - 보안성 향상 기대	- 별도 회선 및 HW 등 단말기 불필요 - 사용자 편의 일부 보장
단점	- 별도 NW 구축, 장비 구매에 따른 비용 - 사용자 불편 및 재부팅 등 시간 소요	- 가상화 환경 구축 비용 소모 - 상대적으로 낮은 보안성

망분리

2. 기존 망분리 제도의 문제점

□ 기존 망분리 제도의 문제점 상세내용

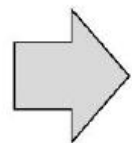
문제점	주요 내용	상세 설명
연구 및 개발	- 오픈소스 활용 불가능	- 외부 오픈소스 라이브러리 연동 문제 발생
	- 인력 운영 어려움 발생	- 원격근무 보장 불가능 및 인력 유출 문제
AI 활용	- AI 적용 서비스 개발 문제	- AI 특성 활용한 외부 학습 데이터 연계, 활용 불가능
	- 시스템 연계 방안 모색 필요	- 데이터 수집, 처리, 활용, 평가 자동화 방안 필요
클라우드 이용	- 클라우드 이용 불가능	- 업권별 특성화 서비스 제공하는 SaaS 이용 불가
	- 구축 비용 및 자원 증가	- 온프레미스 구축에 따른 CAPEX / OPEX 증가 문제
적용범위 불분명	- 도메인 기반 망분리 정책	- 비중요 데이터에 대한 과도한 망분리 규제 적용
	- 과다 대상 적용 문제	- 핀테크, 신규 서비스 개발 업체에 대한 망분리 적용

망분리

3. 망분리 제도의 개선 방안

☐ 데이터 중요도 기반 망분리 규제 개선 방안

<도메인 중심의 망분리>



데이터 중요도
기반 분리

<데이터 중심의 망분리>



망분리

□ 데이터 중요도 기반 망분리 규제 개선 방안 상세 설명

기준	대상	상세 설명
등급 기준	- Confidential (기밀정보)	- 국방, 외교 등 주요 기밀 정보, 물리적 망분리 유지
	- Sensitive (민감정보)	- 민감한 개인정보 포함된 데이터, 망분리 일부 예외
	- Open (공개정보)	- 망분리 비적용 대상, 정보 활용 가능
구현 기술	- 망분리 기술	- 기밀 등급 데이터 위주 망분리 기술 활용
	- 제로트러스트	- 민감정보, 공개정보 대상에 대한 접근제어 수행
	- 인증 및 접근제어	- MFA, IAM 등 사용자 인증 기술 활용, 보안 강화

- 기존 도메인 중심 망분리 개념에서 데이터 중요도 중심 전환

망분리

4. 망분리 정책의 개선, 국가 망 보안체계(N2SF)

□ 국가 망 보안체계(N2SF)

개념	국가 핵심기능과 업무 연속성을 보호하기 위해 기관의 업무정보와 시스템의 중요도 등급 에 따라 일련의 절차 에 따라 보안대책을 차등 적용 하는 사이버보안 프레임워크	
목표	◦ (보안성) 업무 정보의 중요도에 따른 보안통제 차등적용 ◦ (디지털경제 창출) 데이터 유통과 신기술 융합 강화	
정책 전환 배경	현황	2006년부터 국가 공공기관 대상 망 분리 정책 시행
	도입 배경	① IT 환경 변화* 대응의 한계 (*원격근무, 클라우드, 생성형 AI 등) ② 공공데이터의 대국민 활용 제약 ③ 보안정책 패러다임 전환
중요도 3 등급	기밀(C)	「정보공개법」, 국익 저해, 국민 생명에 현저한 지장 초래 정보
	민감(S)	「정보공개법」, 개인정보, 영업비밀, 특정인에 이익/불이익 정보
	공개(O)	「공공데이터법」, 비공개 필요성 소멸 정보, 기밀/민감 外 정보

디지털 보안

4. 보안기술

kpc

한국생산성본부

KPC 정보관리기술사 기본반



4. 보안기술

IAM(Identity Access Management).....	56
ESM(Enterprise Security Management).....	58
SIEM(Security Information and Event Management).....	61
PKI(Public Key Infrastructure)	63
전자서명(Digital Signature).....	65
전자봉투(Digital Envelope).....	68
SSO(Single Sign On).....	70
제로 트러스트(Zero Trust)	72
사이버디셉션(Cyber Deception)	74

IAM(Identity Access Management)

1. 기업 내외부 통합 계정 관리, IAM의 개요

□ IAM (Identity Access Management)의 정의

- AAA 및 Provisioning 기능을 포함한 포괄적인 의미의 IM (Identity Management) 솔루션
- 조직이 필요로 하는 보안 정책을 수립하고 정책에 따라 자동으로 사용자의 계정과 권한 관리 체계

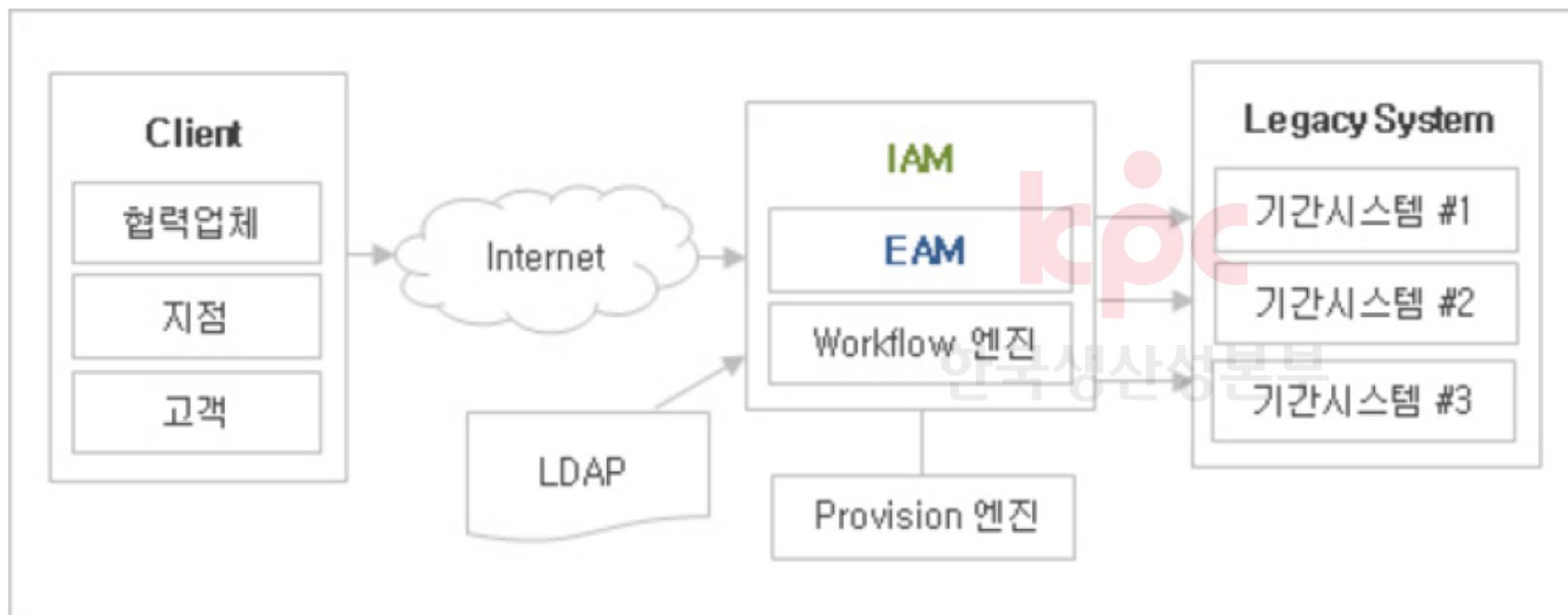
□ IAM (Identity Access Management) 주요 기능

구 분	설 명
프로비저닝	- 자동화된 프로세스를 통해 각 업무 시스템 계정을 통합적 관리 - 사용자가 직접 업무 시스템의 계정을 신청할 수 있는 프로세스
패스워드 관리	- 관리자, 사용자가 통합적으로 자신이 보유한 계정 암호를 변경 - 전사적 암호관리 정책을 통해 일원화된 암호 변경 관리 정책 수행
데이터 동기화	- HR 혹은 계정 원천 정보를 기준으로 한 계정 라이프사이클 관리 - 이 기종 업무 시스템 간의 계정 정보 동기화
감사 및 보고	- 기업에서 발생하는 모든 계정관리 프로세스에 대한 모니터링 - 컴플라이언스 대응을 위한 계정 프로세스의 레포트 제공

IAM(Identity Access Management)

2. IAM의 구성도 및 Identity Manager

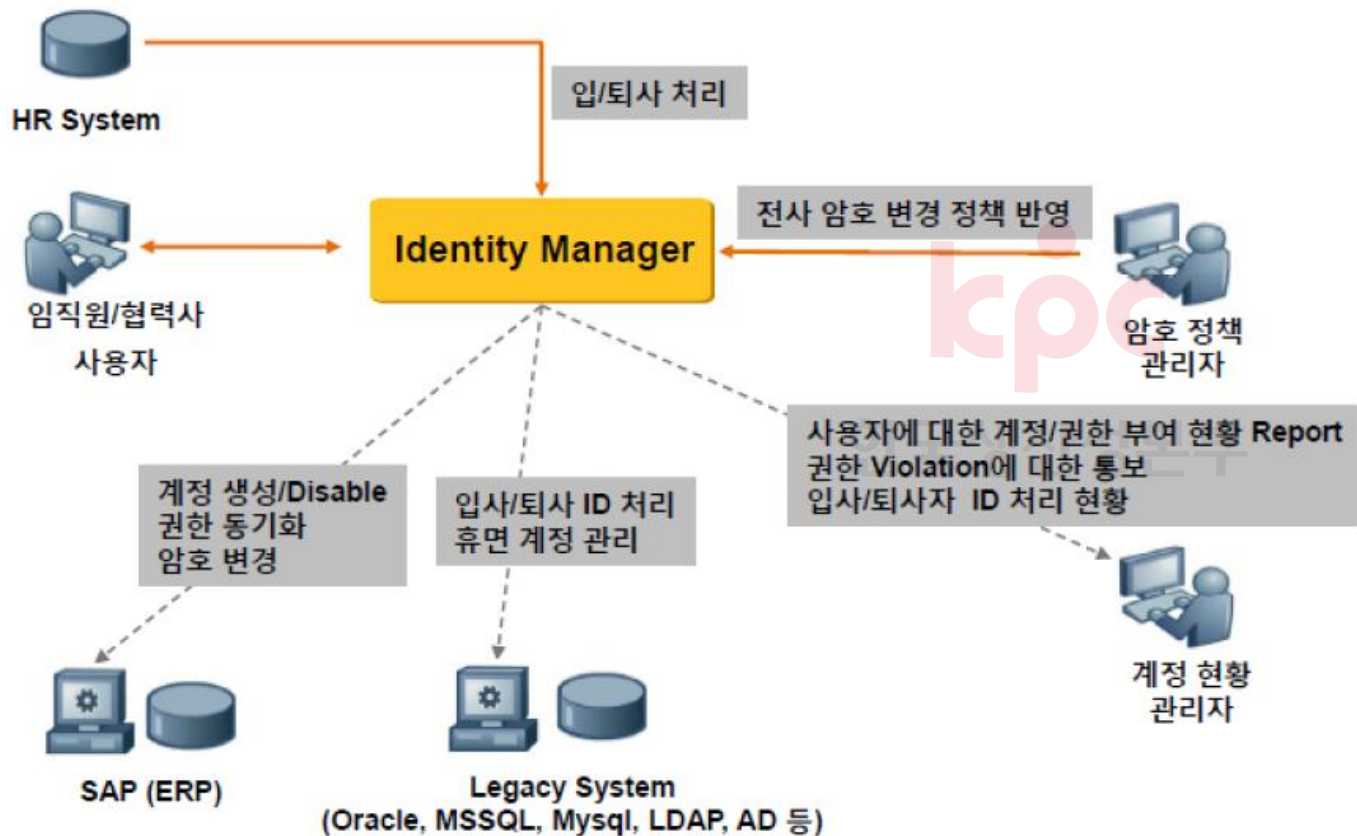
□ IAM의 구성도



IAM = SSO + 권한관리 + 자원관리 및 보안정책 수립 + Provisioning

IAM(Identity Access Management)

□ Identity Manager



ESM(Enterprise Security Management)

1. 통합보안관리, ESM의 개요

□ ESM(Enterprise Security Management)의 정의

- 기업 내 각종 네트워크 보안제품의 인터페이스를 표준화하여 중앙통합관리, 침입종합대응, 통합모니터링이 가능한 지능형 보안관리시스템
- 방화벽, 침입 탐지시스템, 가설 사설망 등의 여러 보안 시스템으로부터, 발생한 각종 이벤트를 관리, 분석, 통보, 대응 및 보안 정책을 관리하는 시스템

□ ESM의 필요성

필요성	특징 및 설명
관리 효율성	- 보안 솔루션을 필요에 따라 도입함으로 인해, 별도의 관리 전문가가 필요 - 일관된 보안 정책 수립이 어려움
비용 절감	- 각각의 보안 솔루션 도입 비용과 관리 비용 중복 투입 방지
성능 개선	- 개별 솔루션에 의한 시스템을 방화벽, VPN, IDS 등 딜레이 타임, 로드밸런싱, 로그 연산기의 통과로 성능에 한계 극복 필요

ESM(Enterprise Security Management)

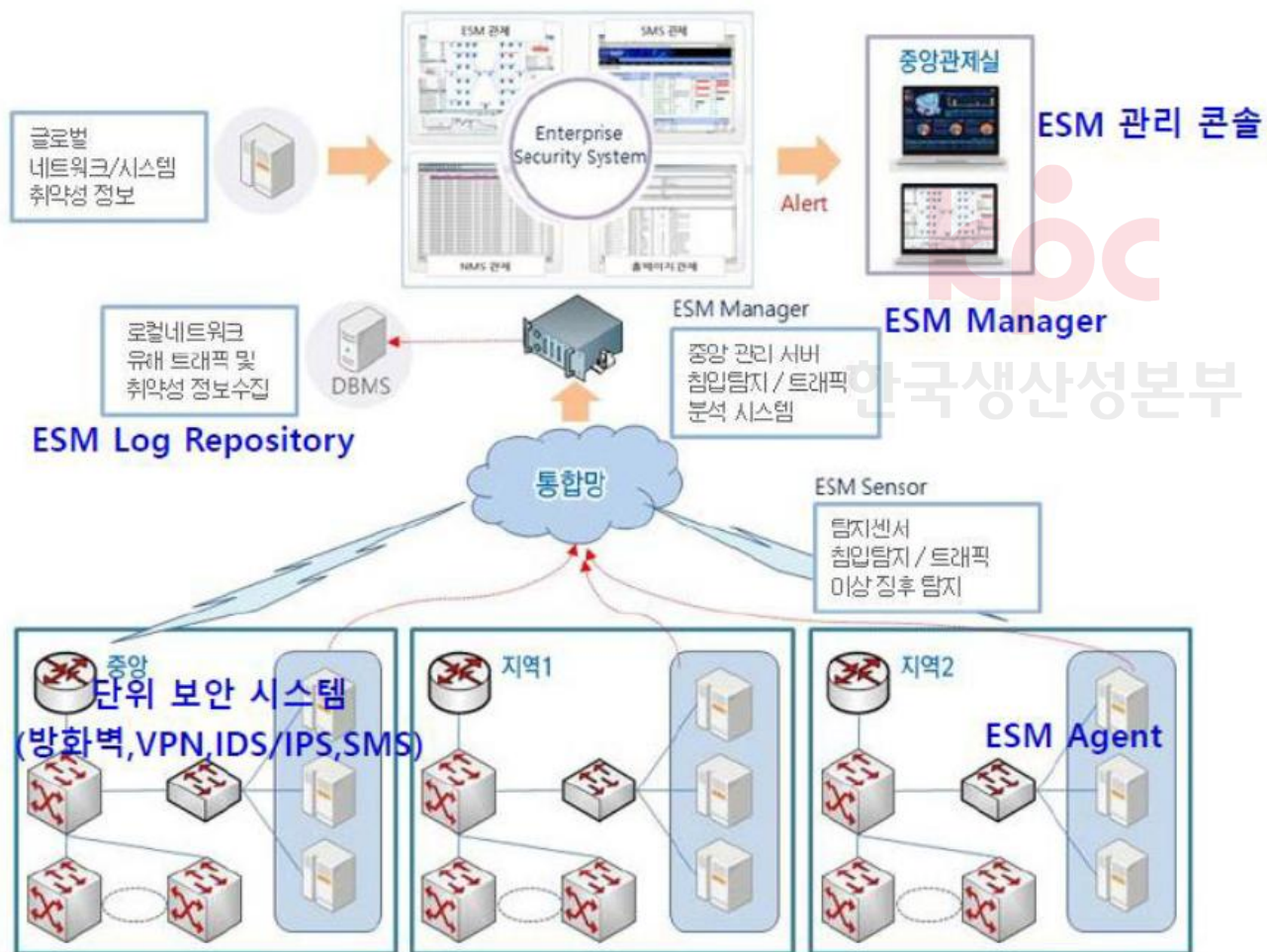
□ ESM의 등장배경

등장배경	내용
단품 위주의 보안 솔루션 한계 노출	- 침입사고의 급증, 공격 유형의 복잡화, 단위 보안 제품으로 대응 불가
보안 시스템 및 업무의 증가	- 보안 시스템의 지속적인 도입으로 인한 운영/관리 업무 증가 - 보안 장비 운영/관리 업무에 필요한 인력의 증가
인력 확보의 어려움	- 보안 장비/시스템에 대한 전문적인 지식 - 각종 OS에 대한 체계적인 지식 - 네트워크에 대한 전문적인 지식 - 보안 사고에 대한 인지 가능 - 보안 사고 대응 가능
비용의 기하 급수적 소요	- 투입 인력 증가 - 보안 장비만 도입하는 것이 아니 지속적인 모니터링 및 관리 필요 - 관제 업무 인력 추가 요구

ESM(Enterprise Security Management)

□ ESM 의 구성도

- 주요구성요소는 단위보안시스템, 통합보안관리시스템, 관리 콘솔을 통한 대응조치로 구성



SIEM(Security Information and Event Management)

1. 지능형 위협 조기 경고 시스템, SIEM의 개요

□ SIEM의 정의

- 빅데이터의 방대한 정보 속에서 단순한 로그 수집 및 분석이 아닌 사후에 추적 등이 가능하도록 상관분석과 포렌식 기능을 제공해주는 지능적 위협에 대한 조기 경고 모니터링 체계

□ SIEM의 등장배경

- 기업의 보안정책 중 외부 해킹 공격에 대한 효과적인 차단과 탐지, 모니터링 등의 전체 운영관리, 심층분석, 대규모 확장성, 통합 뷰의 니즈 증대
- 매일 생성되는 빅데이터급의 로그 증가로 인한 효율적인 로그 관리 및 분석 필요한 로그 관리 및 분석 필요

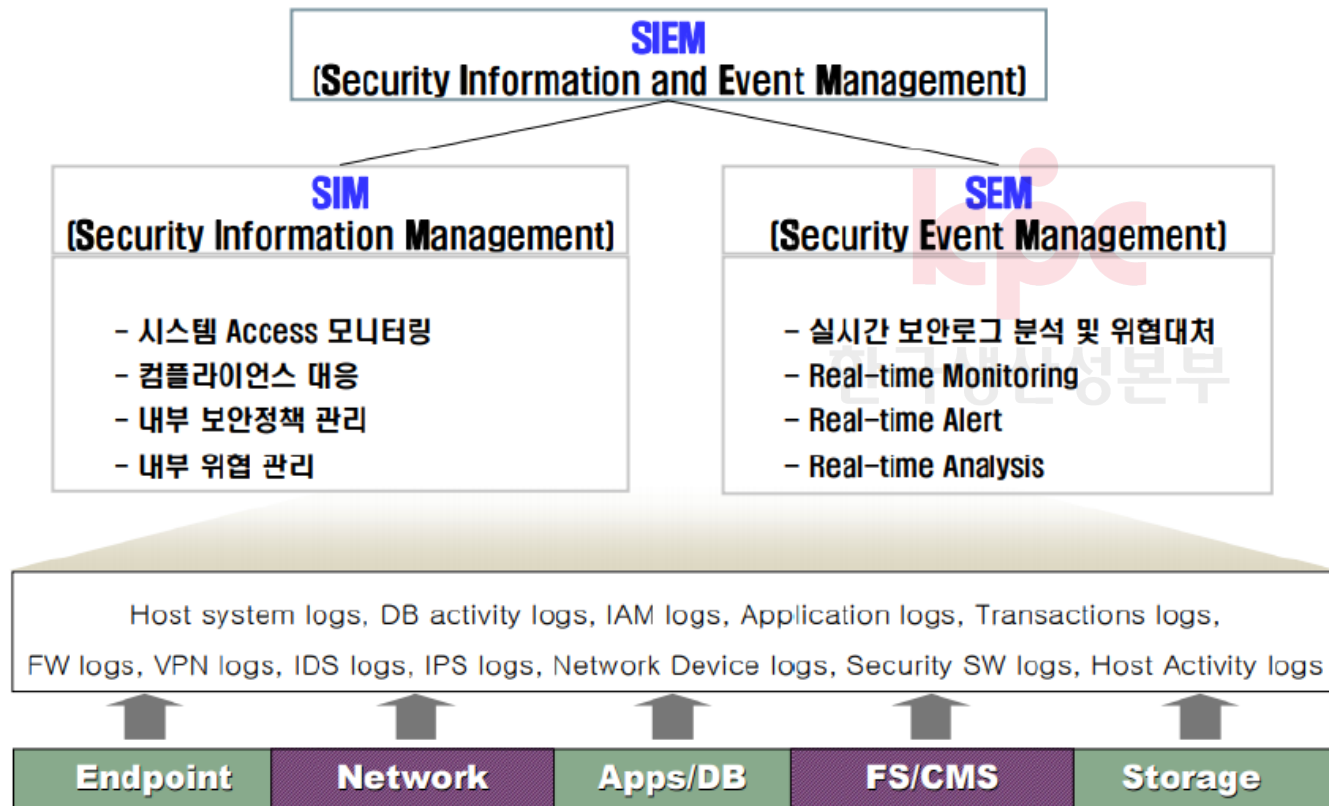
□ SIEM의 특징

특징	설명
자동화	- 위협 탐지에서 대응까지 전 과정 워크플로우 자동화 - 공격 체인 초기에 탐지, 신속한 대응 가능
지능화	- 빅데이터 기반 로그 및 사용자 공격자 행동 분석 - 고객 환경 맞춤형 우선순위 리스크 관리
통합화	- 클라우드 기반 통합 솔루션 제공 - Zero Day 공격 등 최신 보안 위협 효과적 대응

SIEM(Security Information and Event Management)

2. SIEM 의 개념도 및 주요 기능

□ SIEM 의 개념도



SIEM(Security Information and Event Management)

□ SIEM의 주요기능

구분	기능	설명
로그관리	- 수집 로그 무결성 보장	- 에이전트(Agent)를 설치하는 형태와 에이전트 없이 수집하는 에이전트리스(Agentless)방법의 2가지 방법 - 로그 수집 저장하며 무결성 보장
	- E-Discovery 대응	- 기업의 모든 정보가 IT시스템에 저장되는 관계로 법정소송에서 전자기록(E-Discovery)의 중요성이 높아짐에 따라 로그 수집 및 저장 필요성 증대
로그분석	- 로그분석시간 단축	- 기존 ESM기반의 보안관제는 로그의 통합 관리 및 수집 저장에 초점, 로그 분석에는 상당한 시간과 인력이 소요 - SIEM솔루션은 포렌식 및 워크플로우(Workflow) 툴을 제공하여 포렌식에 필요한 평균 해결시간 단축
	- 상관분석을 통한 탐지	- 개별로그의 상관요소별 관계성의 정보(AND, OR조건)을 통해 이벤트를 결정 - 관련 이벤트를 묶어 하나의 공격으로 탐지될 수 있는 룰셋을 제공

SIEM(Security Information and Event Management)

2. SIEM 과 ESM 의 상세비교

구분	SIEM	ESM
특징	- 통합적 지능화된 대응	- 독립적인 목적 수행
대응시점	- 로그의 패턴 기반 실시간 대응	- 로그 분석 후 대응
탐지유형	- 예측, 추이, 상관분석	- 룰 기반, 패턴 DB기반
이상탐지	- 정황 및 행위 패턴	- 쿼리, 조회기반
관리대상	- 기존 솔루션 시스템 포함, 네트워크 장비, 어플리케이션, S/W등 전사적	- 보안시스템, 서버시스템
분석대상	- 기존포함, 시스템감사정보, 네트워크 흐름, 웹 활동 포함	- 로그, Event, 경고

PKI(Public Key Infrastructure)

1. 공개키⁴ 기반의 인프라 구조, PKI의 개요

□ PKI(Public Key Infrastructure)의 정의

- 인증기관(CA) 에서 공개키와 개인키를 포함하는 인증서(Certificate)를 발급받아 네트워크상에서 안전하게 비밀통신을 가능하게 하는 기반구조
- 공신력 있는 제3 인증기관에 의한 거래주체의 인증, 거래정보의 무결성과 기밀성, 거래의 부인방지 기능을 담당하는 공개키 기반의 인프라

□ PKI의 특징

특징	내용
부인봉쇄	- 상거래 당사자가 수행한 상거래 행위를 부인할 수 없도록 하는 기능 - 전자서명 기술을 사용
인증	- 비대면 거래의 문제를 해결하기 위한 상거래 당사자들의 정당성 확인 - 전자인증서 기술을 사용
무결성	- 정당한 권한을 가지지 못한 제3자에 의한 데이터변경 및 접근 차단
기밀성	- 정당한 권한을 가진 사용자만 데이터를 볼 수 있도록 하는 기능 - 암호화 기술을 사용

PKI(Public Key Infrastructure)

□ PKI의 중요성

- 개인 키 관리 및 인증하기 위한 CA의 운영을 통하여 대칭키 암호방식의 운영상 한계 극복 가능함
- 키의 분실이나 배상의 어려움에 대한 해소 방안임
- 웹 상의 비즈니스나 안전한 거래를 보증하기 위한 대안으로 등장함.

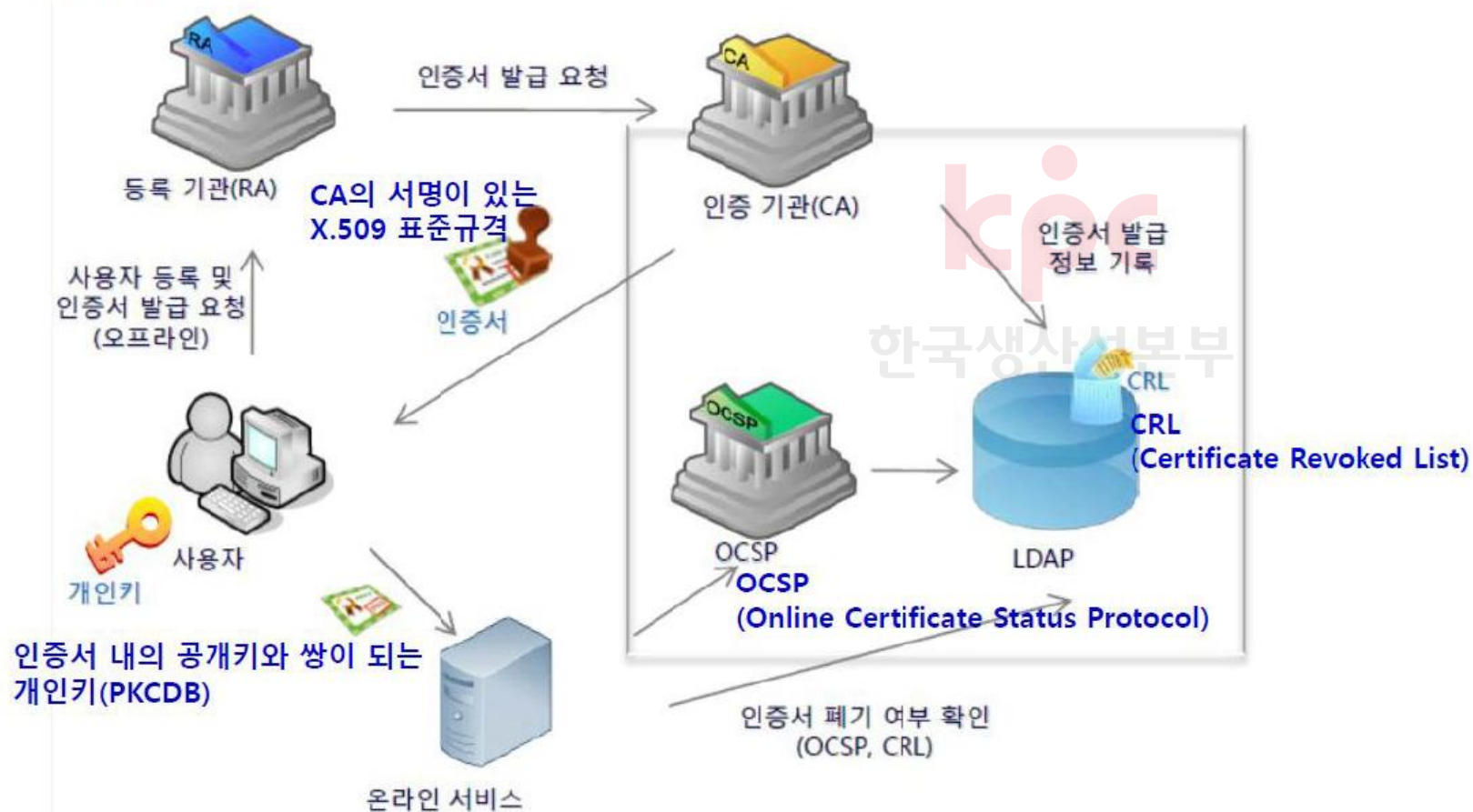
□ PKI의 필요성

보안관점	필요성
관리적 보안	- 개인키 관리 및 인증하기 위한 CA 운영 필요(인증서 : X.509)
물리적 보안	- 비대면 환경에서 신분을 보장할 수 있는 증명서 필요
기술적 보안	- 개인키에 대한 CA 운영을 통해 대칭키 암호방식 한계 극복 - 키 분실이나 분배상 어려움을 해결할 수 있는 방안 필요 - 웹 상의 비즈니스나 안전한 거래를 보증하기 위한 대안 필요

PKI(Public Key Infrastructure)

2. PKI의 구성도 및 구성요소

□ PKI의 구성도



PKI(Public Key Infrastructure)

□ PKI의 구성요소

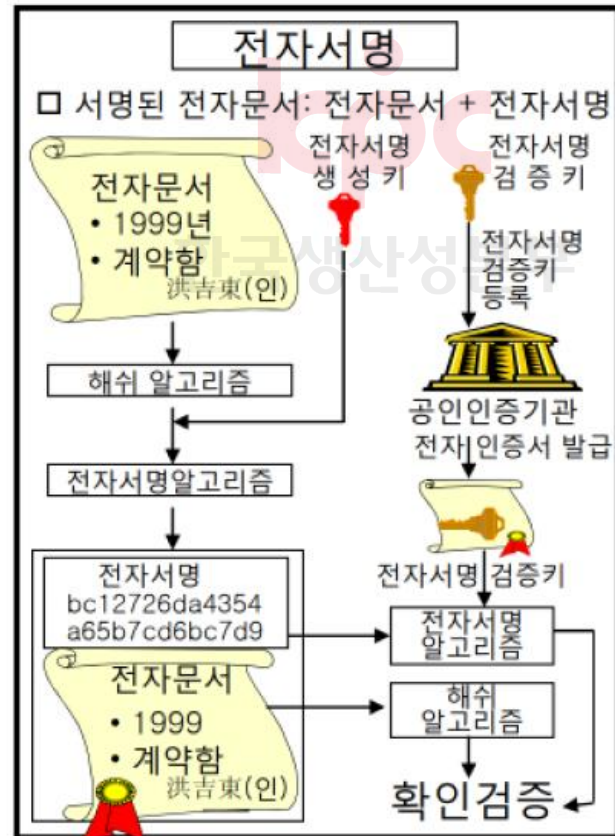
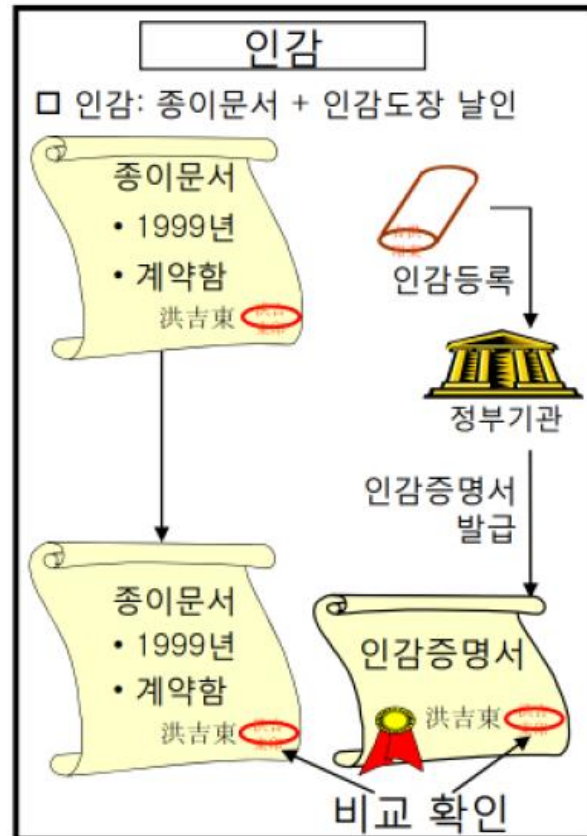
구성요소	설명
인증기관 (CA)	- Certificate Authority - 인증서의 등록, 발급, 조회 등 관리를 총괄하며 CRL(Certificate Revocation List)를 생성
등록대행기관 (RA)	- Registration Authority - 사용자의 요청이 있을 경우, 사용자의 신원을 확인하고 CA에 인증서 발급을 요청 - 인증서 등록 및 사용자 신원확인을 대행
Certificate Repository	- 인증서 및 인증서 폐기 목록(CRL)을 보관 - CA, RA로부터 인증서 및 CRL을 받아 저장하고, PKI 구성요소 중 하나의 요청이 있을 경우 데이터 제공
디렉토리	- Certificate Repository를 포함하여 인증서 및 CRL을 저장하고 사용자에게 서비스하는 역할 - 주로 LDAP을 이용하여 디렉토리 서비스 제공 - 인증서는 서명검증의 응용을 위해 디렉토리에 저장
사용자	- 인증서를 신청하고 인증서를 사용하는 주체

전자서명(Digital Signature)

1. 전자서명(Digital Signature)의 개요

□ 전자서명 정의

- 전자문서를 작성한 작성자의 신원과 당해 전자문서가 그 작성자에 의해 작성되었음을 나타내는 전자형태의 서명



전자서명(Digital Signature)

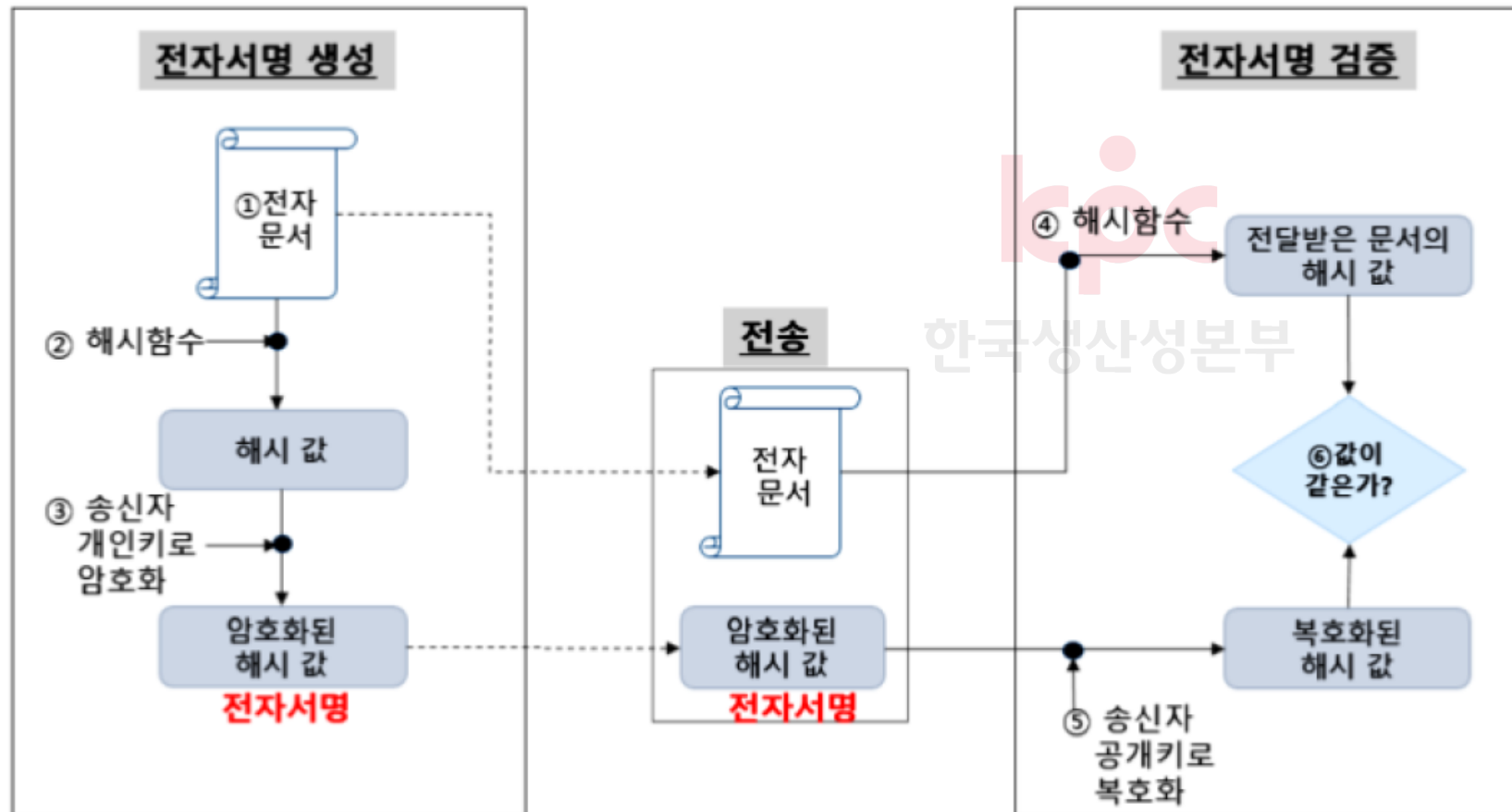
□ 전자서명의 요건

요건	설명
위조불가(Unforgeable)	- 생성키를 소유하지 않은 자는 전자서명 생성 불가 - 서명자만이 서명문을 생성 가능
서명자 인증 (Authentication)	- 생성키를 소유한 자가 전자서명의 행위자이며 전자서명의 서명자를 불특정 다수가 검증할 수 있어야 함 - 서명문의 서명자를 확인 가능
부인방지(Non Repudiation)	- 서명자는 후에 서명 사실 자체를 부인할 수 없어야 함
변경불가(Unalterable)	- 생성키를 소유하지 않은 자는 전자서명한 문서의 내용을 변경할 수 없어야 함
재사용 불가 (Not Reusable)	- 전자문서의 서명을 다른 전자문서의 서명으로 대치 및 사용할 수 없어야 함
분쟁해결가능 (Judge)	- 제3자에 의해 정당성을 검증 받을 수 있어야 함

전자서명(Digital Signature)

2. 전자서명 절차 및 검증방법

□ 전자서명 원리



전자서명(Digital Signature)

구분	동작	설명
생성	① 원문 전자문서 생성	- SHA, SHA2, MD5 등의 해시 알고리즘을 사용하여 해시값 추출
	② 해시값 추출	- 작성자의 개인키를 이용하여 메시지 다이제스트 암호화
	③ 개인키 암호화	- 생성된 해시값을 송신자의 개인키로 암호화하여 전송
검증	④ 해시값 추출	- 전송받은 전자문서 해시함수 통해 해시값을 추출
	⑤ 공개키 복호화	- 송신자의 공개키를 이용하여 전송받은 전자서명을 복호화
	⑥ 해시값 비교	- ④번과 ⑤번의 값이 동일한지 비교, 즉 무결성 검증 - 동일하면 무결성 보장, 그렇지 않으면 변조

전자서명(Digital Signature)

□ 전자서명 구현기술

요소기술	설명	종류
공개키 암호화 알고리즘	- 개인키/공개키 쌍을 이용한 전자서명 및 전송 기술 - 개인키를 사용하여 전자서명 - 공개키를 사용하여 문서 검증	- RSA 전자서명 - KCDSA 전자서명
해쉬함수	- 일방향성 성질 - 메시지 압축 기능 - 일정한 값의 압축문서 생성	- SHA-1, 2 - MD5
메시지 다이제스트	- 해쉬함수에 의해 생성된 압축문서	- 해쉬함수 - 전자서명 검증

전자봉투(Digital Envelope)

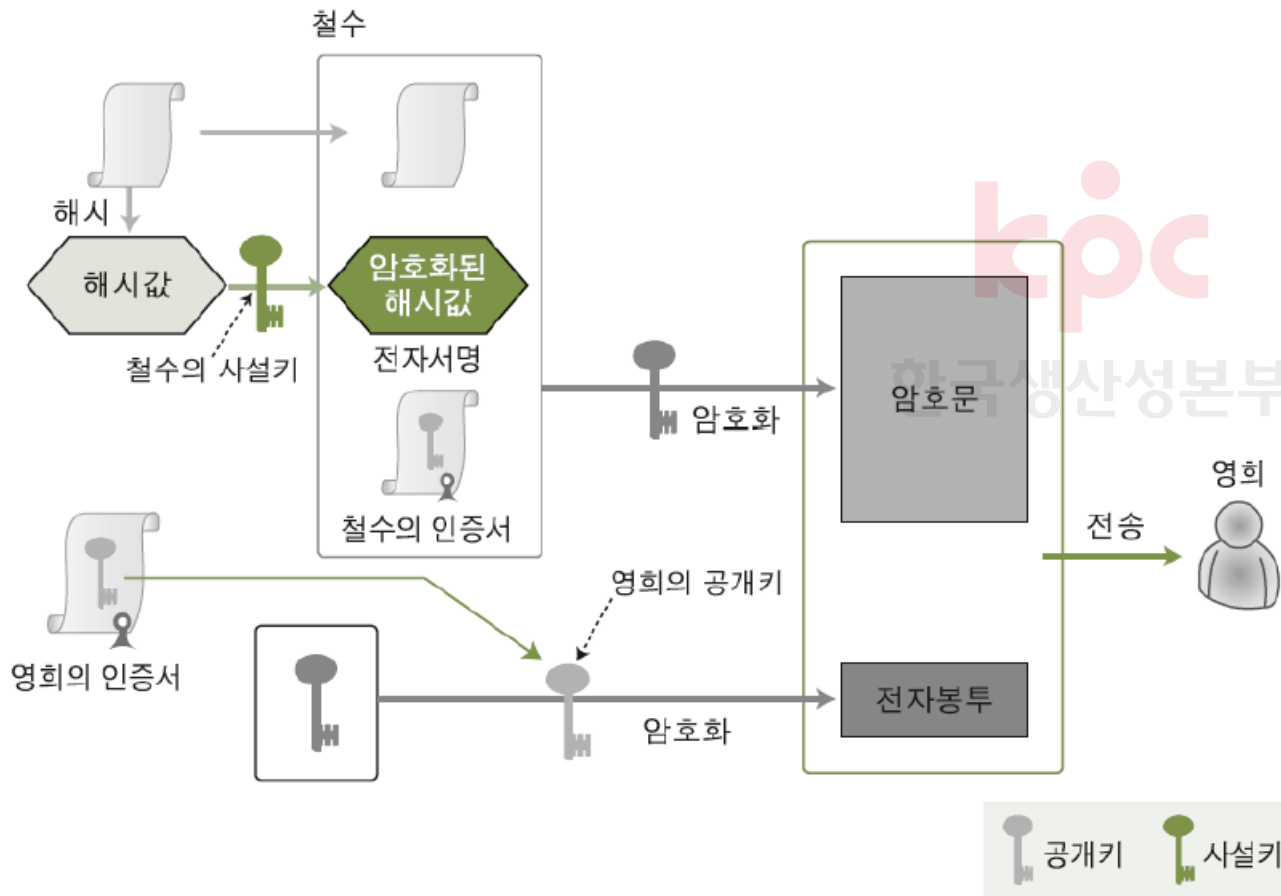
1. 전자봉투(Digital Envelope)의 개요

- 송신자가 송신내용을 암호화 하기 위하여 사용한 비밀키(secret key, 대칭키)를 수신자만 볼 수 있도록 수신자의 공개키(비대칭키)로 암호화 시킨 전자화된 봉투
- 송신자는 전자봉투를 사용하기 위해 우선 전자서명을 생성하고 전자서명과 원문, 그리고 자신의 공개키가 들어있는 인증서를 비밀키(DES 알고리즘 등에 사용되는 대칭키)를 사용하여 암호화함. 전자서명 세트와 인증서를 암호화한 비밀키를 수신의 공개키로 암호화하며 이것이 전자봉투가 됨.
- 전자봉투는 기밀성, 무결성, 부인 방지를 모두 지원함.

전자봉투(Digital Envelope)

2. 전자봉투 암호화 및 복호화 과정

□ 전자봉투 암호화 과정



1. 전송하는 철수는 자신의 사설키(개인키)를 이용하여 서명을 생성

2. 전송의 효율성을 고려하여 비밀키를 생성하여 원문, 전자서명, 철수의 인증서를 암호화

3. 비밀키를 영희에게 안전하게 전달하기 위해 영희의 공개키로 비밀키를 암호화하여 전송. 이것을 전자봉투라고 함

SSO(Single Sign On)

1. 정보시스템에 대한 통합인증관리, SSO의 개요

□ SSO (Single Sign On)의 정의.

- 한번의 시스템 인증을 통하여 관련 SSO를 지원하는 다수의 정보 시스템에 재 인증 절차 없이 사용할 수 있게 하는 기능.

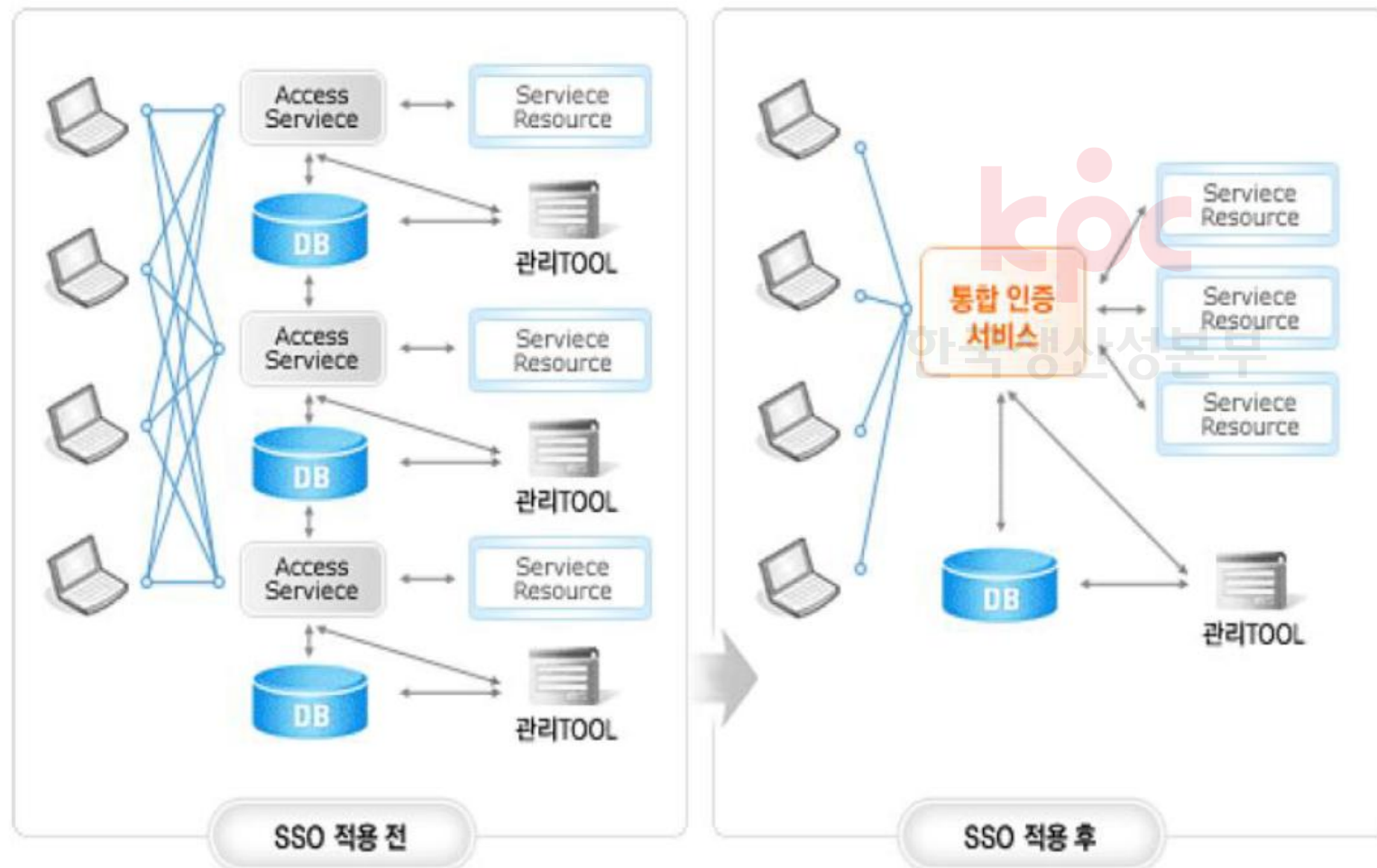
□ SSO의 특징.

비즈니스적	- 인증된 기관으로부터 시작되는 SSO 인증 절차는 사용자에게 신뢰감 - 사용자 정보를 저장하고 관리할 추가 리소스 투자 비용이 적음
기술적	- SSO를 지원하는 시스템에 별도의 ID와 PASSWORD를 제공할 필요 없음 - Application 서버는 별도의 모듈 설치 혹은 REST등의 기술을 통해 SSO 서버와 통신을 하게 되며 SSO 서버는 높은 가용성이 요구됨
관리적	- 중앙 관리를 통한 업무의 순환 및 표준화 실현 - 중앙 집중적 사용자 관리를 통한 보안 기능의 강화

SSO(Single Sign On)

2. SSO의 구성도 및 구성요소.

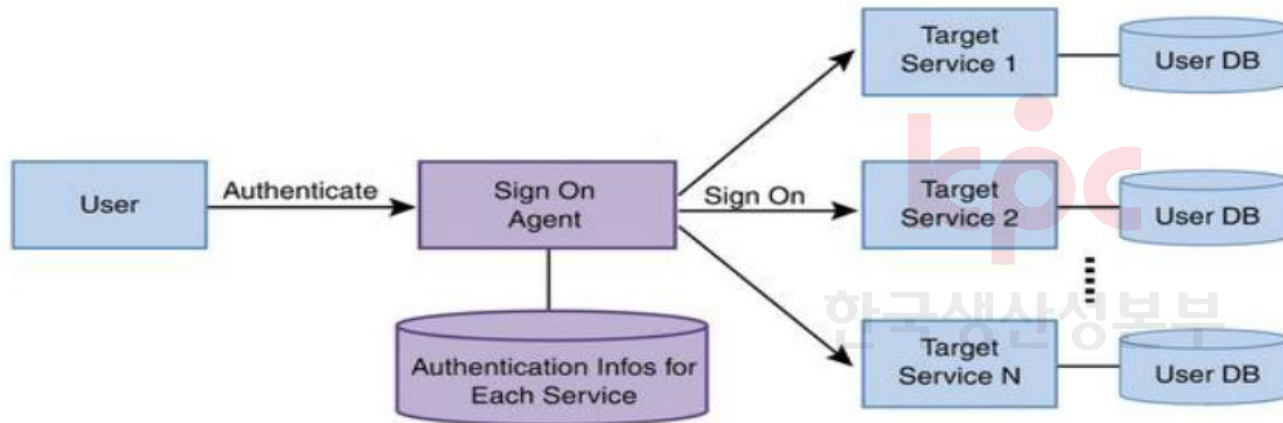
□ SSO의 구성도



SSO(Single Sign On)

3. SSO 모델

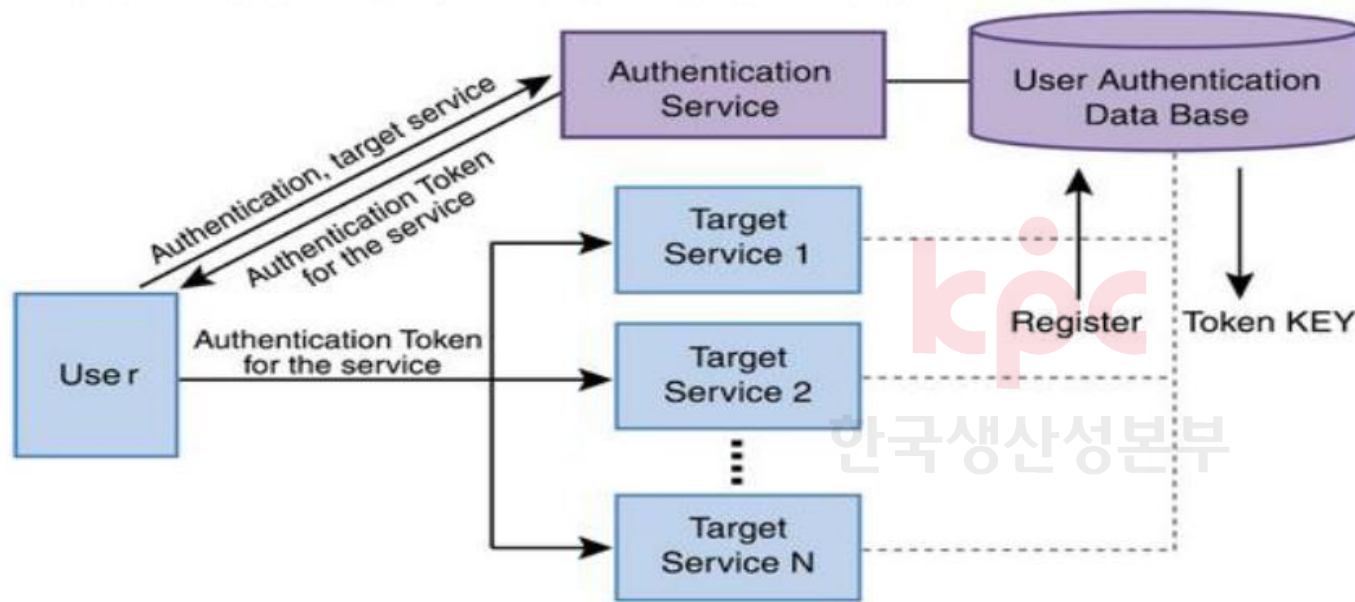
□ 인증대행 모델(Delegation)



- 인증방식을 변경하기 어려울 때 많이 사용됨
- 애플리케이션 인증 정보를 에이전트가 관리해 사용자 대신 로그인 해주는 기능
- ID/PASS 의 집중화로 유출 우려
- C/S나 패키지 소프트웨어도 SSO통합가능

SSO(Single Sign On)

□ 인증정보 전달모델(Propagation)



- 통합 인증을 수행하는 곳에서 인증을 받아 대상 애플리케이션에 전달한 Token을 발급
- 웹 환경에서는 쿠키라는 기술을 이용해 Token을 자동으로 대상 애플리케이션에 전달 가능

제로 트러스트(Zero Trust)

1. 개별 데이터 중심의 보안모델, 제로 트러스트(Zero Trust)의 개요

□ 제로 트러스트 정의

- 기업 내 외부를 막론하고 누구도 신뢰해서는 안되며, 시스템에 접속하고자 하는 모든 것에 접근권한을 부여하기 전 인증을 거쳐야 하는 보안 모델
- 모든 데이터 혹은 특정 데이터 하나하나의 보안을 강화하는 보안 모델 (2010, Forest Reasearch)

□ 제로 트러스트의 부각 배경

**글로벌 해킹 조직
공격 증가**

**엔데믹 악용
사이버 공격 지속**

**랜섬웨어, 피싱업
사회공학 진화**

**기업 SW 공급망
위험 증가**

사이버 보안 위협 고도화



경계기반 보안의 한계

* Lateral Movement



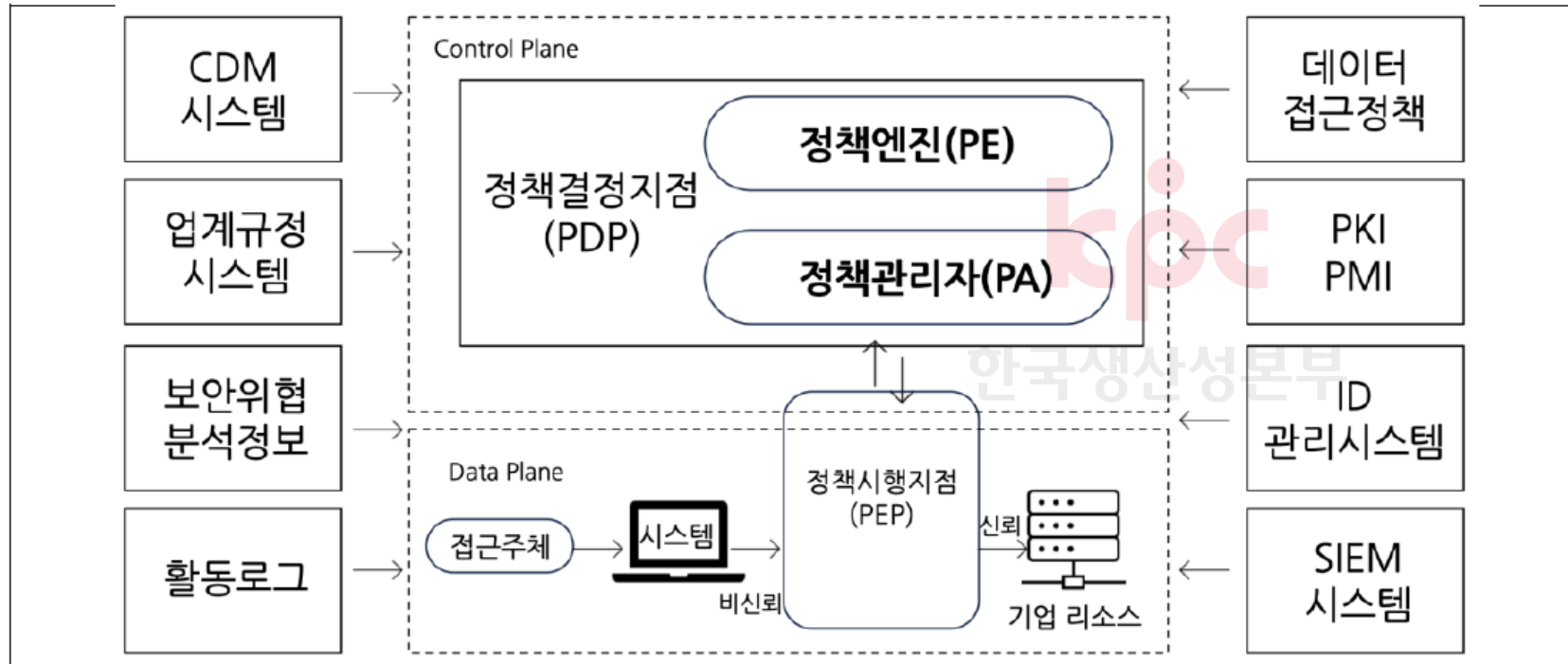
신뢰(Trust)의 배신

* 신뢰 부여 → 리스크 상승

제로 트러스트(Zero Trust)

2. 제로 트러스트 보안모델 개념도 및 구축단계 설명

□ 제로 트러스트 보안모델 개념도



- 제로 트러스트 아키텍처를 실행하기 위해서는 많은 논리 컴포넌트가 필요

제로 트러스트(Zero Trust)

□ 제로 트러스트 아키텍처의 구성요소

구분	구성요소	설명
핵심 논리 컴포넌트	정책 엔진(PE)	- 주체의 리소스 액세스 허가 여부 최종 결정 - 허가/거부/취소
	정책 관리자(PA)	- 정책 집행 포인트에 명령하여 주체와 리소스 사이의 통신 경로를 설정하거나 폐쇄 - 정책 관리자는 세션별 인증/인가 토큰 또는 크리덴셜을 생성
	정책 집행 지점(PEP)	- 정책 집행 포인트는 주체와 기 업 리소스 사이를 연결하고, 모니터링하고, 최종적으로 연결을 종료
데이터소스	8 가지 로컬데이터 소스	- 상시 진단/보완 시스템(Continuous diagnostics and mitigation, CDM) - 업계 컴플라이언스 시스템 - 위협 인텔리전스 피드 - 액티비티 로그, - 데이터 접근 정책 - PKI - ID 관리 시스템 - SIEM

- NIST 에서 제로트러스트의 7 가지 기본 원리를 제안

제로 트러스트(Zero Trust)

3. 제로 트러스트 7 가지 기본 원리

- ① 모든 데이터 소스와 컴퓨팅 서비스는 리소스로 간주한다.
- ② 네트워크 위치에 관계없이 모든 통신은 보호된다.
- ③ 개별 기업 리소스에 대한 접근을 세션 단위로 승인된다.
- ④ 리소스에 대한 접근은 동적 정책으로 결정된다. 이 동적 정책은 클라이언트 식별자, 응용·서비스, 요청 자산에 대한 상태를 포함하고, 그 외에도 다른 행동·환경 속성을 포함할 수 있다.
- ⑤ 기업은 모든 자산의 무결성 및 보안 상태를 감시·측정한다.
- ⑥ 모든 리소스에 대해 접근 허용 이전에, 동적으로 강력하게 인증·인가 조치가 이루어져야 한다.
- ⑦ 기업은 자산, 네트워크 인프라, 통신 등 현 상태에 대해 가능한 많은 정보를 수집해야 하며, 보안 상태를 개선하기 위해 사용해야 한다.

사이버디셉션(Cyber Deception)

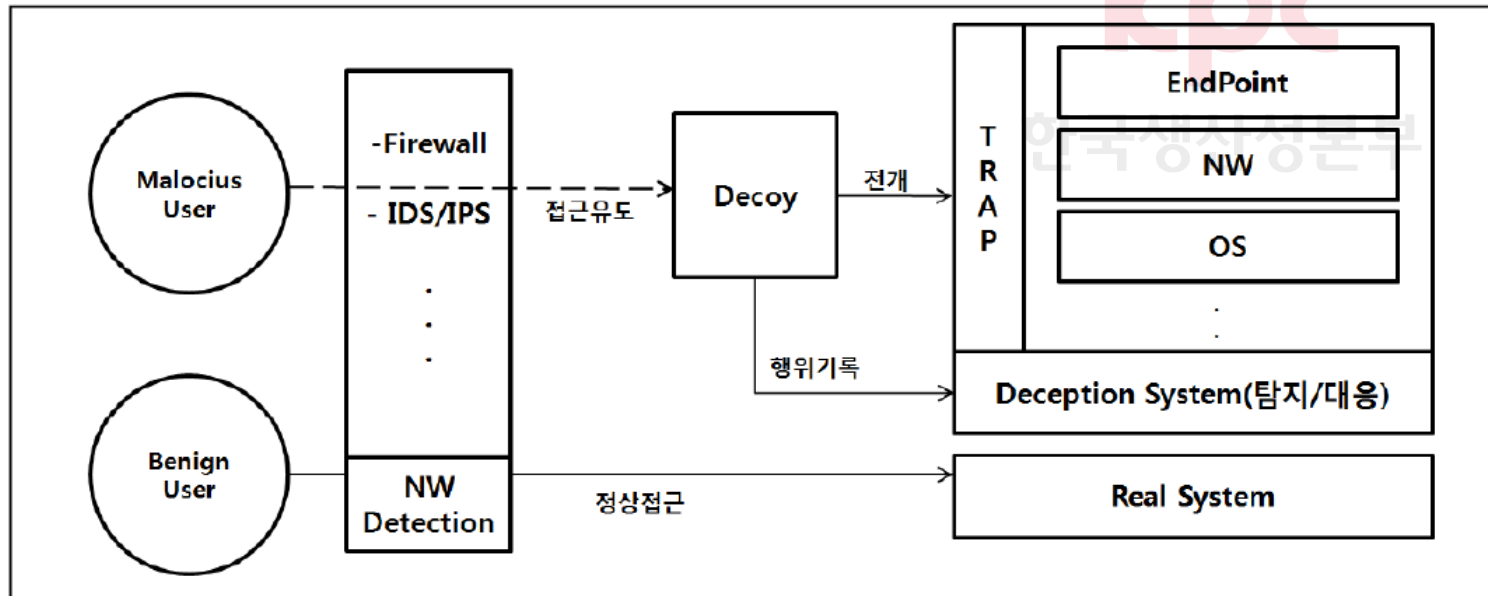
1. 엔드포인트 보안을 위한 허니팟의 한계 극복, 사이버 디셉션의 개요

□ 사이버 디셉션 정의

- NW, 엔드포인트 등에서 위협이 주변으로 확산되기 전에 미끼(Decoy)와 함정(Traps)을 이용해 실시간으로 유인, 탐지, 예방 하는 보안 기술

2. 사이버디셉션의 매커니즘 및 구성요소 설명

□ 사이버 디셉션의 매커니즘



- 공격자를 미끼와 함정을 통해 가짜 트랩으로 유도 후 접근, 악성코드 다운로드, 경로 등을 실시간으로 탐지

사이버디셉션(Cyber Deception)

□ 사이버 디셉션의 구성요소

분류	구성요소	설명
Decoy(미끼)	- 쿠키	- 스크립트의 기록서(HTTP), 로컬에 저장되는 기록 정보 파일
	- 서버접근정보	- IP주소, MAC, 접속시간 정보, 접속기간 정보
	- 로그인정보	- 계정정보, 접근 경로, 권한 정보, 사용 명령어
	- 자동생성기술	- 방화벽 및 유사 내부정보를 활용한 접근 포인트 생성
Trap(함정)	- EndPoint	- 에이전트 정보, 방화벽, 경로별 정보 유도, USB, 포트
	- Network	- 가상 유도 NW, 트래픽 생성, Access Control, 이메일 정보
	- OS	- Root 정보, 사용자 인증, 접근제어 허가, 메모리 유도
Eception System	- NW 탐지	- 이상접근, 미끼기반 모니터링, 랜섬웨어 확인, 현상파악
	- 포렌식	- 정당성 확보를 위한 근거 추출, 이상현상에 대한 원인 분석
	- User Interface	- 실시간 트래픽 모니터링, 포트 등 다경로 시각화 수행/제공

사이버디셉션(Cyber Deception)

3. 사이버디셉션과 허니팟 비교

비교 항목	사이버디셉션	허니팟
대응범위	- 내/외부 접근	- 외부접근
라이선스	- 라이선스 최소화	- 가상화 등 많은 라이선스 필요
오탐율	- 오탐율 최소화(제로화)	- 오탐지 높음
탐지방식	- 포괄적 탐지(자동화 구현/확장)	- 로그분석 기반
확장	- 포괄적 배치	- 제한적 배치

- 정해진 특징 중심의 IT 자산만 허니넷으로 구축할 수 있었으나 사이버디셉션은 IoT 및 IIoT, 의료기, PLC, 리눅스 등 다양한 시스템을 에뮬레이션할 수 있어서 IoT 보안에서의 활용도가 매우 높음

디지털 보안

5. 정보화 역기능

kpc

한국생산성본부

KPC 정보관리기술사 기본반



5. 정보화 역기능

해킹(Hacking).....	78
DDoS(Distributed Denial of Service)	80
DBD(Drive By Download)	84
랜섬웨어(Ransomware).....	86
다크웹(Dark Web)	87

해킹(Hacking)

1. 네트워크, 보안 망 등에서 보안 취약점의 악의적 이용 혹은 피해를 주는 행동, 해킹의 개요

□ 해킹(Hacking)의 정의

- 컴퓨터 네트워크의 보안 취약점을 찾아내어 이를 악의적으로 이용하는 행위.
- 시스템 관리자가 구축해 놓은 보안 망을 무력화 시키거나, 시스템 관리자 권한을 불법적으로 획득 및 악용해 다른 사용자에게 피해를 주는 일체의 행동

□ 최근 해킹 공격의 특징

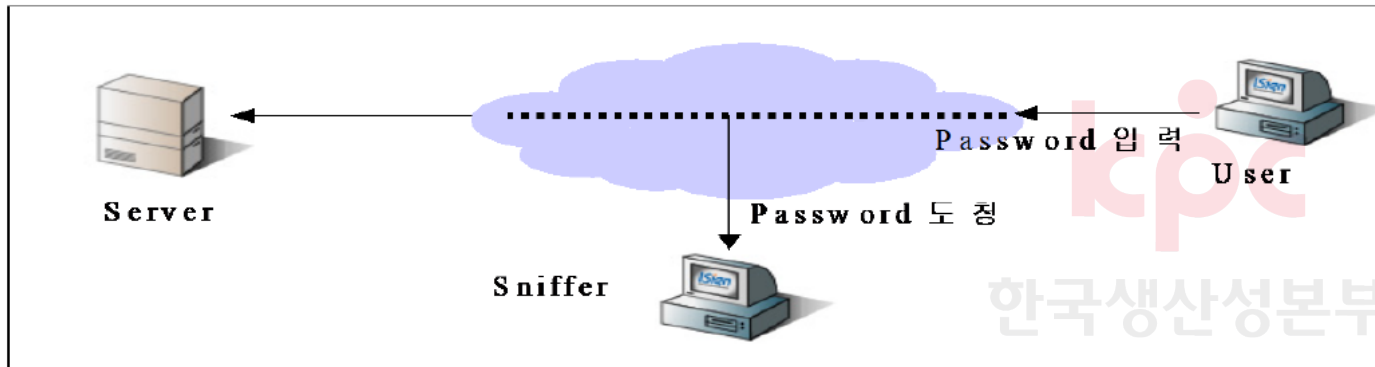
구 분	내 용
자동화(Automation)	- 인터넷 웹 및 윈도우용 공격도구 최근의 공격스크립트의 자동화
에이전트화(Agent)	- 원격명령으로 공격을 수행 하거나 에이전트 기반 빠른 정보 입수
분산화(Distributed)	- 원격조정 가능한 Agent형 백도어를 설치하고 다른 시스템을 공격하는 방법
은닉성(Stealth)	- Agent를 이용한 분산공격기법은 침입탐지시스템을 무력화 할 수 있는 공격으로 공격자의 위치를 은닉

해킹(Hacking)

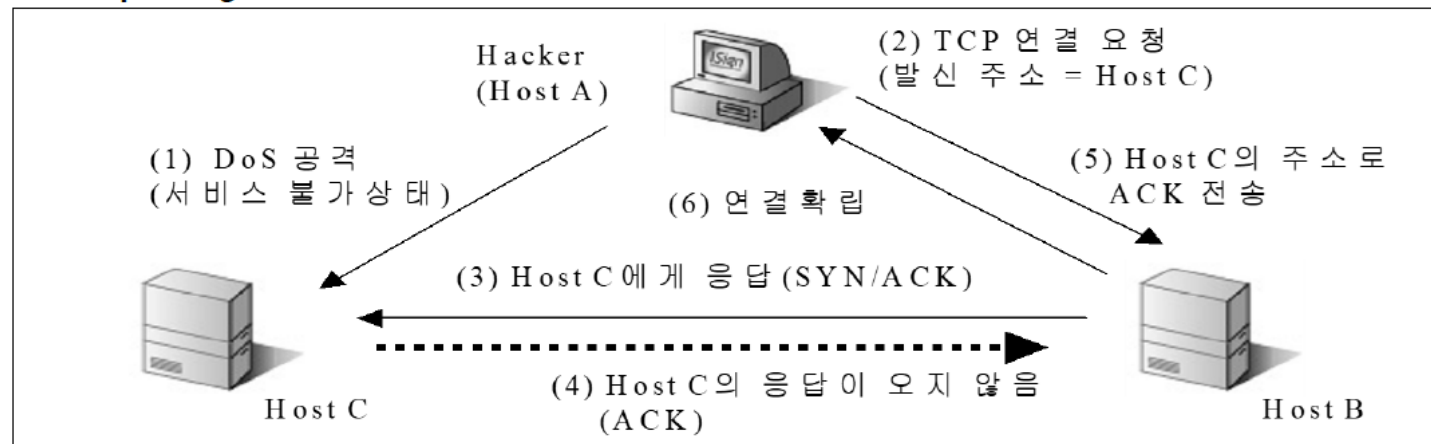
2. 해킹의 기법

□ Sniffing

- 스니퍼는 '컴퓨터 네트워크상에 흘러 다니는 트래픽을 엿듣는 도청장치'
- 스니핑은 스니퍼를 이용하여 네트워크상의 데이터를 도청하는 행위



□ IP Spoofing



해킹(Hacking)

1) IP Spoofing 의 정의

- TCP/IP의 구조적 결함에서 출발한 방법으로 TCP 시퀀스 번호, Source routing, 소스 IP 주소를 이용해서 상대방 호스트가 자신의 호스트를 트러스트하게 만드는 해킹 방법 (spoof: 속이기/속임수)
- IP 주소 등의 정보를 속임으로써 권한을 획득하고 중요 정보를 가로채어, 서비스 방해까지 행하는 TCP/IP 프로토콜 결함을 이용한 해킹 공격

2) IP 스푸핑 기법 공격절차

- 1단계: 패킷의 내용을 변경하여 스크리닝 라우터와 방화벽 통과
- 2단계: 소스 IP 주소를 조작하여 자신을 신뢰성 있는 호스트로 인식
- 3단계: 원하는 호스트의 초기 시퀀스번호를 알아냄
- 4단계: 트로이 목마 등의 프로그램 설치, 호스트 접근 권한 혹은 루트 권한 획득

DDoS(Distributed Denial of Service)

1. DDoS(Distributed Denial of Service) 공격

□ DDoS(Distributed Denial of Service)의 정의

- 서비스에 대한 정당한 접근을 방해하거나 차단하고자 네트워크에 분산되어 있는 많은 에이전트를 이용하여 공격대상 서버에 동시에 과도한 서비스요청을 발생시키는 공격

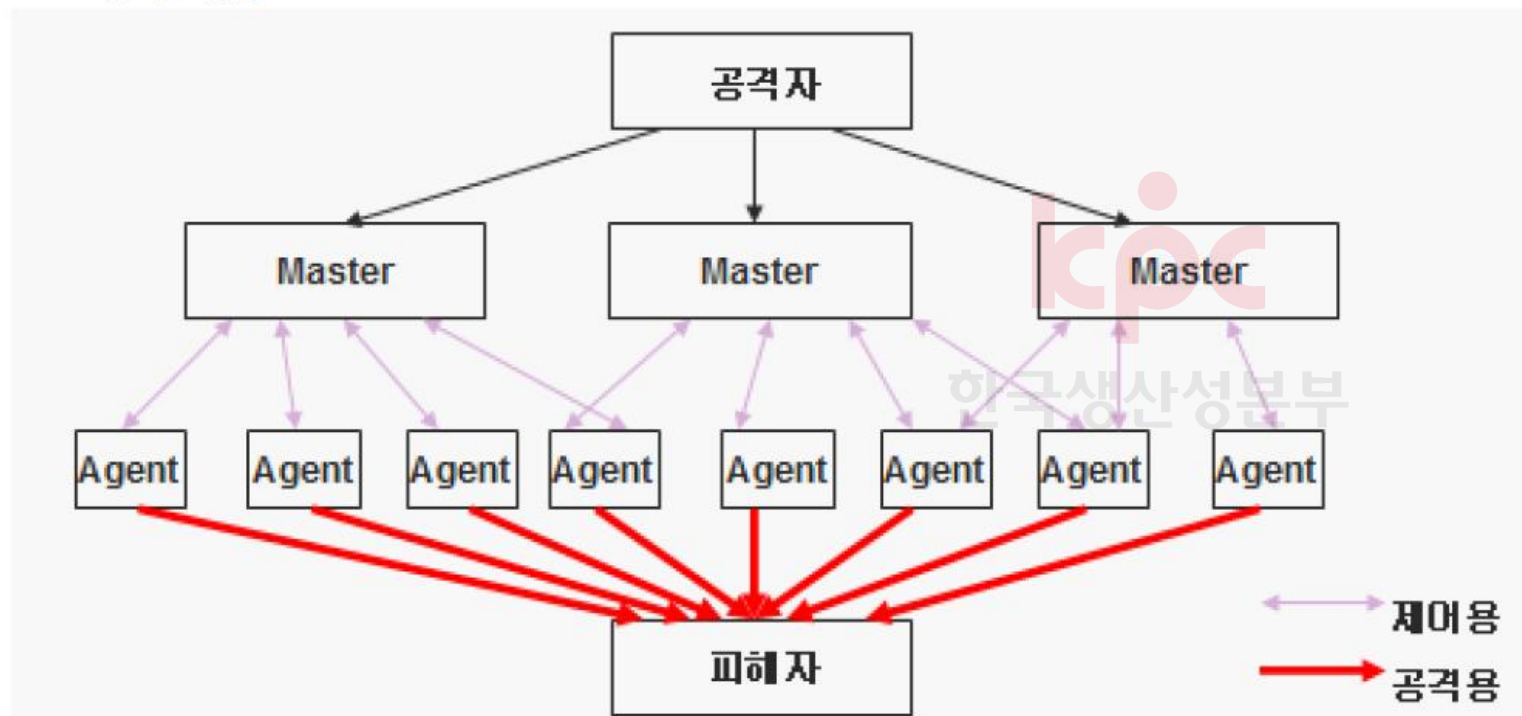
□ DDoS의 특징

특징	설명
은닉 분산공격	- 네트워크에 분산되어 분포하는 좀비인 에이전트를 이용하여 공격 - 일반 사용자의 컴퓨터에 은닉한 악성코드를 통해서 사용자가 인식하지 못하는 동안 공격 수행
방어의 어려움	- 네트워크에 분산되어 공격함으로써 모든 소스를 차단하기 어려움 - IP를 위조하거나 에이전트를 변경하여 공격함으로써 차단이 어려움
랜섬(Ransom) 공격	- 공격자는 DDoS공격을 통해서 피해자의 서비스를 마비시킨후, 협박을 통해서 공격중단을 대가로 금전적이 보상을 요구함

DDoS(Distributed Denial of Service)

2. DDoS 공격 개념도 및 구성요소

□ DDoS 공격 개념도



DDoS(Distributed Denial of Service)

□ DDoS 공격 구성요소

구성요소	설명
공격자(Attacker)	- DDoS공격을 주도하는 공격자의 컴퓨터를 의미함
마스터(Master)	- 여러대의 DDoS에이전트의 연결을 관리하는 시스템 - 공격자에게 직접 명령을 받아 에이전트에게 명령 전달을 실행함
에이전트(Agent)	- 일반 사용자의 컴퓨터에 은닉하며 마스터에 연결하여 관리되는 악성코드 - 마스터의 명령에 따라 공격대상(Victim)에 직접적인 공격하는 시스템

한국생산성본부

DDoS(Distributed Denial of Service)

3. DDoS의 공격유형 및 공격기술

□ DDoS의 공격유형

항목	PPS 증가	웹서비스 지연	대용량 트래픽 전송
사용 프로토콜	TCP	HTTP	UDP/ICMP
공격사례	Syn flooding TCP Connection flooding	HTTP flooding	UDP flooding ICMP flooding
공격형태	64byte 이하 크기로 수십만~수백만 PPS 발생	동일 URL 접속 시도	1000~1500byte 패킷으로 수십 Gbyte 트래픽 발생
공격영향	네트워크 장비, 보안장비, 서버등의 부하 발생	웹서버 부하 발생	회선 대역폭 고갈
피해범위	공격 대상 시스템, 동일 네트워크의 모든 시스템	공격 대상 웹서버	동일 네트워크에 사용중인 모든 시스템
IP Spoofing	변조/실제 IP	실제 IP	변조/실제 IP

DDoS(Distributed Denial of Service)

□ 공격기술

분류	공격명	설명
PPS 증가	Syn flooding	- IP를 변조후 다량의 Syn 패킷을 공격 대상 서버로 전송하여 공격받은 서버는 다수의 SYN_RECEIVED 세션 상태 발생 - 서버의 CPU 및 Connection 자원의 고갈 유도
	TCP Connection Flooding	- 다량의 Syn 패킷을 공격 대상자 서버로 전송하고 공격 대상 서버에서 다수의 ESTABLISHED 세션 상태 발생 - 서버의 CPU 및 Connection 자원 고갈 유도
	TCP Out-of-State Packet flooding	- 다량의 ACK/SYN+ACK/FIN/RST등의 패킷을 공격대상 서버로 전송 - 일부 네트워크 장비 및 서버의 CPU 부하발생 및 오작동

DDoS(Distributed Denial of Service)

웹서비스 지연	HTTP flooding	- 정상적인 HTTP GET 또는 POST를 이용하여 상품조회와 같은 반복적인 요청을 전송 - 웹서버 및 데이터베이스 서버의 CPU 및 Connection 자원고갈
	CC Attack	- HTTP의 Cache control 메시지를 이용하여 Cache 서버를 거치지 않고 직접 웹서버에 HTTP 요청 - 직접적인 요청으로 인한 웹서버 CPU 및 Connection 자원 고갈
대용량 트래픽 전송	UDP/ICMP flooding	- 1000~1500 byte정도의 큰 UDP/ICMP 패킷을 서버로 전송 - 공격대상 네트워크의 대역폭을 고갈시켜 서비스 마비 유도

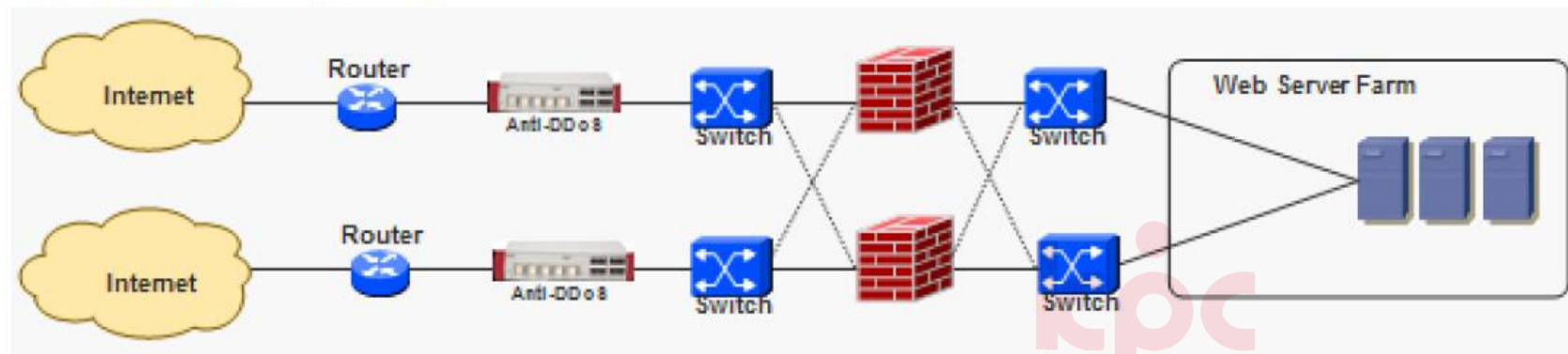
DDoS(Distributed Denial of Service)

□ DDoS 공격유형별 방어기술

분류	방어기술	설명
PPS 증가	비정상 IP 차단	- RFC1918에서 지정한 비공인 IP 차단 - 멀티캐스팅, 사설 IP등 특정 목적을 가진 IP 차단
	공격 IP 차단	- 공격 근원지 IP를 조사하여 IDC/ISP와 공조하여 트래픽의 Null routing(Ignored) 처리를 통한 공격 트래픽 차단
	Syn Proxy 사용	- Syn Proxy/Cookie 기능을 제공하는 보안 장비 및 네트워크 장비를 이용하여 비정상적 TCP 패킷 차단
	장비 패치	- 취약한 네트워크 장비 및 서버에 대한 패치
웹서비스 지연	서버 설정변경	- KeepAlive를 Off로 변경, Maxclient를 최대수치로 조정
	웹서버 증설	- 서비스를 위한 웹서버의 추가를 통한 부하 분산
	공격 IP 차단	- 공격 근원지 IP에 대한 방화벽 또는 라우터에서 차단
대용량 트래픽 전송	불필요한 서비스차단	- 가능한 네트워크 최상단에서 불필요한 UDP 및 ICMP 서비스 차단
	공격 IP 차단	- 공격 근원지 IP를 조사하여 IDC/ISP와 공조하여 트래픽의 Null routing처리를 통한 공격 트래픽 차단
	DNS 서버 다중화	- 다중 DNS 서버를 운영하여 제 3의 등록기관에 DNS 등록

DDoS(Distributed Denial of Service)

□ Anti-DDoS 솔루션 구성



- 네트워크 행위분석기반(Network Behavior Analysis)의 DDoS 공격 대응 전용시스템 도입
- 시그니처 기반의 비정상 패킷 차단, 행위기반의 DDoS 차단과 사용자 정의 규칙(Rule)에 의한 DDoS 차단 기능을 제공함

DBD(Drive By Download)

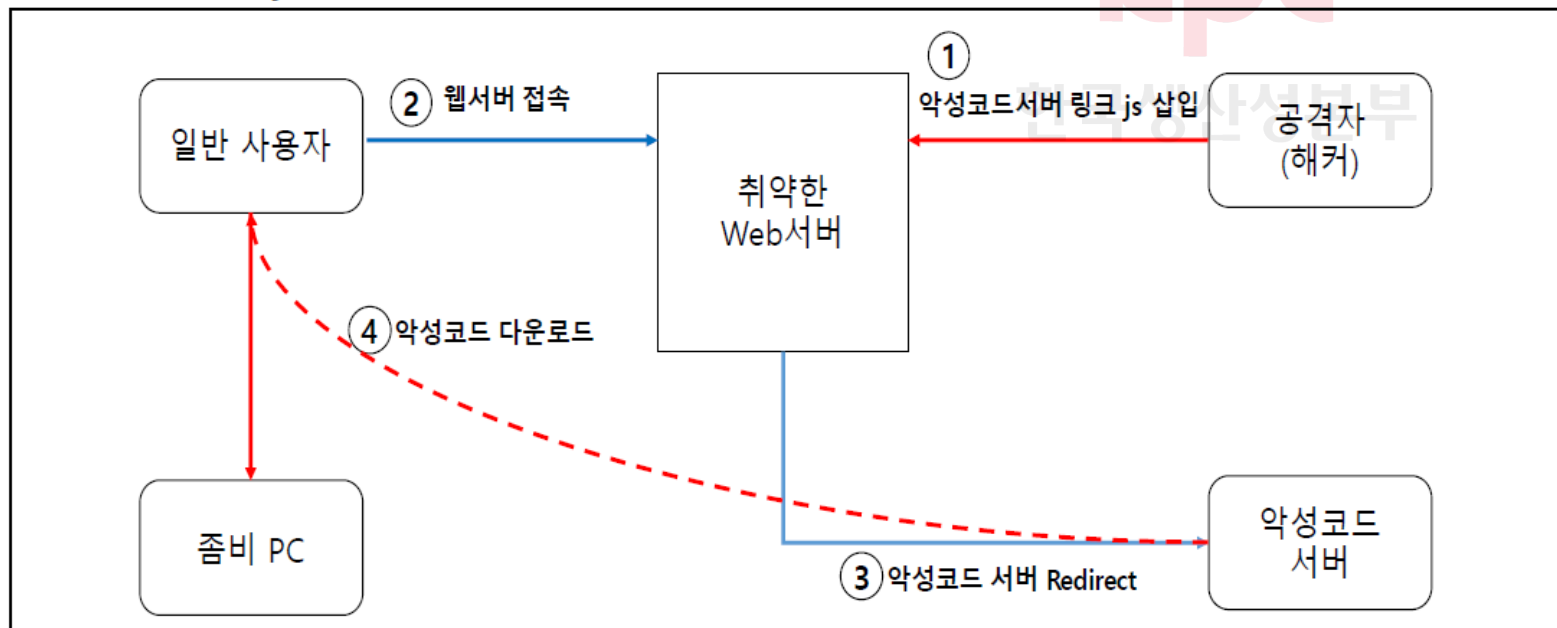
1. DBD(Drive By Download)의 개요

- [개념] 웹브라우저나 플러그인, 브라우저에서 동작하는 컴포넌트의 취약성을 악용하여 사용자가 인지하지 못하는 사이에 악성SW가 사용자PC에 다운로드 되도록 만드는 공격기법

* 페이지간 자동이동 : <iframe>, <frame>, <javascript> 등 사용하여 사용자 행위없이 페이지 이동 가능하게 삽입

2. DBD (Drive By Download)의 공격 Mechanism 및 단계별 공격기술

□ DBD (Drive By Download)의 공격 Mechanism



- 해커는 보안이 취약한 웹페이지에 iframe 및 스크립트 등을 통해 피해자를 유포지로 자동연결

DBD(Drive By Download)

□ DBD (Drive By Download)의 단계별 공격기술

#	구분	공격기술	상세설명
1	취약점 공격	- Exploit Kit - Injection	- 취약한 웹서버에 악성코드 서버 링크 삽입 - Iframe, frame, javascript 사용하여 사용자 행위없이 페이지 이동 가능하게 삽입
2	사용자 방문	- javascript - 쿠키/세션 악용	- 사용자가 평소에 방문하던 웹사이트 방문 - Object, embed 등의 태그가 적용되어 사용자가 인지하지 못하게 객체 숨김처리
3	자동연결	- page redirect	- 악성코드 서버(경유지 서버)에서 악성코드 자동연결 - SendRedirect("/악성코드 서버주소")를 통해 해커가 사전에 준비한 악성코드 서버로 이동
4	악성코드 실행	- 코드변형, 은닉 - C&C서버 연결	- 사용자 PC에 악성코드가 자동 실행되어, 취약한 웹서버 방문자의 PC가 자동으로 좀비PC화 - 프로세스 실행과 동시에 은닉

- 피해자는 악성코드가 설치되는지 인지 못하는 경우가 대부분이기 때문에 다양한 측면에서 대응방안이 요구

DBD(Drive By Download)

□ DBD (Drive By Download)의 대응방안

구분	대응방안	상세설명
기술적 측면	- 플러그인 업데이트 - 웹-필터링 SW - NoScript 설치 - 자바 비활성화 - BLADE 사용 - 권한관리	- 구형 버전 브라우저와 플러그인의 업데이트로 취약점 제거 - DBD 의심 사이트에 대한 접근차단 - 신뢰할 수 있는 사이트에서만 스크립트, 자바, 플래시 실행 - PDF리더 설정에서 문서내 자바스크립트 비활성화 - DBD악용에 취약한 윈도우 기기를 위한 방어 시스템 - 로컬 관리자 권한의 제한으로 치명적인 피해 방어가능
분석기법 (정적/동적)	- 패턴매칭 - 메타정보분석 - DOM 파싱 - 스크립트 에뮬레이션 - VM기반 검증	- 웹페이지 내 포함된 웹 코드, 유포에 사용되는 함수 등 특정 문자열 탐지 - 웹페이지 URL, DNS, IP, 국가정보 등 페이지 정보 분석 - 웹페이지 DOM구조 분석 - 웹페이지 내 포함된 스크립트 실행 및 결과분석 - 최종 웹페이지 다운로드 행위 및 다운로드한 실행파일 분석

랜섬웨어(Ransomware)

1. 랜섬웨어(Ransomware)의 정의

- 몸값을 뜻하는 Ransom과 SW의 합성어로서 사용자의 중요 파일, 데이터등을 암호화하고 이를 볼모로 금전적 댓가를 요구하는 악성프로그램

유형	설명
스케어웨어 (Scareware)	- 팝업창을 통해 지속적으로 감염사실을 사용자에게 알리며 금전요구
락스크린 바이러스 (Lock-Screen Virus)	- FBI나 사법부 로고가 담긴 풀사이즈 윈도우를 띄우며 벌금납부 유도를 통해 금전갈취를 노림
네스티 스템프 바이러스 (Nasty Stuff Virus)	- 컴퓨터 내의 개인중요파일을 암호화하고 금전요구

- 최근에는 네스티 스템프 바이러스 유형인 Crypt0L0cker, Cryptowall의 발생빈도가 90% 이상임

랜섬웨어(Ransomware)

2. 랜섬웨어의 감염경로와 방지방법

□ 랜섬웨어의 감염경로

감염경로	공격방식	설명
이메일	- 스피어 피싱,	- 특정 대상의 인물들에게 정보 업데이트를 요구하여 정보 갈취
위/변조된 웹사이트	- 워터링 홀 - 드라이브 바이 다운로드 - 파밍, DNS 포이즈닝	- 자주가는 웹사이트에 악성코드 삽입 후 사이트 접속 시 감염시킴 - OS나 SW취약점을 통해 웹사이트 변조 후 방문시 악성코드 유포
첨부파일/악성코드	- 사회공학	- 친분관계, 신분관계를 이용하여 첨부파일 클릭, 악성코드 실행 유도

랜섬웨어(Ransomware)

□ 랜섬웨어 방지방법

구분	방지 방법	상세
관리적 측면	- 불필요한 파일 다운로드 금지 - 각종 Add-On 프로그램 설치시 사이트 서명 확인 - 사내 PC 및 서버 최신보안패치 적용	- 사용자 보안인식 제고 - 주기적 교육 및 모의훈련 - 비상연락망 구축
물리적 측면	- 중요파일 주기적 백업 보관 - 파일별 개인암호설정, 읽기전용(Read-Only) 설정	- Private Cloud, 백업장비 활용 - 파일 권한 설정
기술적 측면	- 백신 실시간 감시기능 On - 행위기반 악성코드 탐지 - 발신지 불분명 이메일 사전차단	- 각종 웹사이트 접속 시 실시간 감시 및 유해 사이트 사전 차단

다크웹(Dark Web)

1. 다크웹(Dark Web)의 개요

□ 다크웹의 개념

- 비표준적인 통신 규약과 포트를 사용하는 특정 소프트웨어, 설정, 또는 허가가 있어야 접속할 수 있는 오버레이 네트워크(Overlay Network)
- 일반 검색 엔진으로 검색되지 않고 불법 정보 유통과 암거래가 주로 이루어지는 다크넷(Darknet)의 집합체

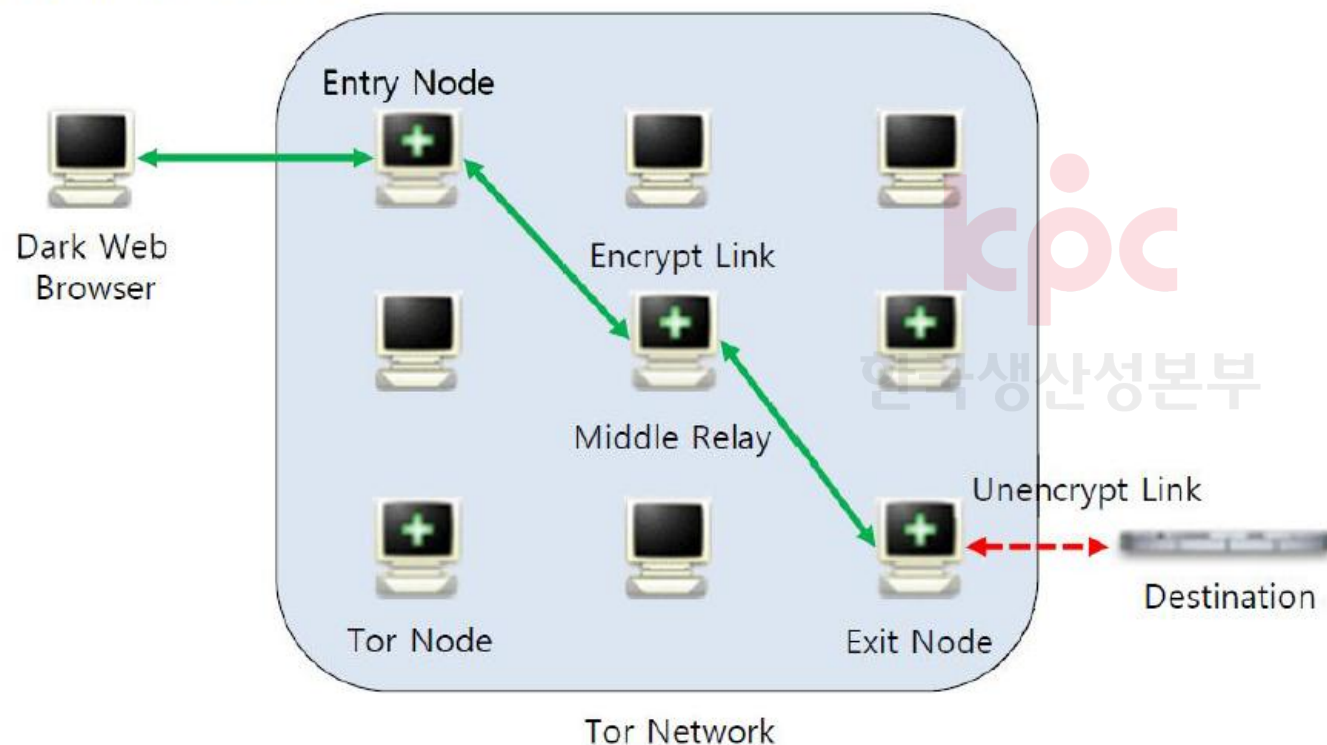
□ 다크웹의 특징

프로세스	내용
익명성 제공	- 암호화 통신 등을 적용하여 추적 불가능
블랙 마켓(Black Market)	- 다크 웹 각종 사이버 범죄 행위 거래가 이뤄 지는 온라인 마켓
가상 화폐	- 블랙 마켓에서 대금 결제를 위한 수단으로 추적이 어려운 비트 코인, 이더리움, 대쉬, 모네로 등을 이용

다크웹(Dark Web)

2. 다크웹의 중심 토르(Tor)네트워크 연결 구조와 종류

□ 토르(Tor)네트워크 연결 구조



다크웹(Dark Web)

□ 토르(Tor)네트워크 연결 구성요소

구분	사례	설명
도메인	abc, union	- 일반 검색 엔진에서 검색 불가능한 도메인 주소
네트워크	TOR 서버, E2C	- 3개 이상의 Relay(Entry, Middle, Exit)를 경유하도록 설계 - 공유 서버에서 Relay가 구축되며, 일정 시간마다 변경
암호화	Onion Routing, VPS	- 경로상에서 3중으로 암호화 - Exit Node에서 최종 목적지(Destination)으로 가는 경로를 제외하고 모두 암호화로 보호
브라우저	Tails	- 검색과 접속을 위해 별도의 전용 브라우저 사용
전자화폐	비트코인	- 결제 및 매매는 익명성이 보장되는 전자 화폐를 이용

다크웹(Dark Web)

3. 다크웹의 대응 방안

구분	대응 방안	설명
기술적 대응 방안	크롤링 수집	- 스캐닝, 크롤링(Crawling)을 통해 얻은 정보를 분석하여 다크웹 정보 수집
	핑거프린팅(Fingerprinting) 분석	- 핑거프린팅(Fingerprinting) 등의 방법을 통해 다크웹(Dark Web) 서버 식별 및 추적
	가상 화폐 추적	- 비트 코인, 이더리움, 대쉬 등의 가상 화폐 추적을 통한 다크 웹(Dark Web) 이용자 추적
	토르 네트워크(Tor Network) 분석	- 토르 네트워크(Tor Network)의 특정 노드를 장악한 후 트래픽 분석
제도적 대응 방안	모니터링 수행	- 다크 웹(Dark Web) 상시 상시 모니터링 기관 운영
	공조 체계 구축	- 국내 각 부처 및 산하 기관 공조 체계 구축과 국가간 공조 체계 구축
	유해 사이트 정보 제공	- 다크 웹(Dark Web) 유해 사이트 수사 기관 의뢰, 관련 정보 제공
	연구, 추적 기술 개발 지원	- 다크 웹(Dark Web) 관련 연구 및 추적 기술 개발 기관 육성

디지털 보안

6. 개인정보 보호기술

kpc

한국생산성본부

KPC 정보관리기술사 기본반



6. 개인정보 보호기술

개인정보 비식별화	91
ISMS-P.....	93



개인정보 비식별화

1. 개인정보 비식별화의 개념

☐ 개인정보 비식별화의 개요

규칙 기반 비식별화

- 암호화
- 삭제
- 가명화
- 해부화

통계 기반 비식별화

- 통계 활용
- 일반화
- 무작위화
- 재현 데이터

- Data 내 개인 식별이 가능한 요소 전부 또는 일부를 삭제/대체하여, 개인을 알아볼 수 없도록 하는 기술
- 비식별화 정도가 높을수록 데이터의 유용성은 떨어지지만 프라이버시 침해 위험도는 낮아짐

개인정보 비식별화

□ 비식별화된 개인정보가 가질 수 있는 식별가능성 유형

취약점 유형	설명
개별화 가능성 (single out)	- 데이터셋에서 특정 레코드의 일부 혹은 전체가 한 개인에게 대응될 가능성
연결 가능성 (linkability)	- 최소 2 개 이상의 레코드들이 동일한 데이터주체를 가리켜 서로 연결될 가능성
추론 가능성 (inference)	- 데이터셋의 속성값들로부터 특정 개인에 해당하는 임의의 속성 값을 상당히 높은 확률로 유추할 가능성

개인정보 비식별화

2. 개인정보 비식별 조치 기술의 유형

☐ 규칙 기반 비식별화

유형	상세 유형	설명
암호화	결정성 암호화	- 평문이 같을 시 동일 암호값 생성
	순서/형태보존 암호화	- 원 데이터의 순서 또는 형태 보존
	동형 암호화	- 암호화 상태에서의 사칙연산이 가능
삭제	식별자 삭제	- 레코드 삭제, 컬럼 삭제, 부분 삭제
	마스킹	- 대체, 형태보존암호화, 스크램블링(순서 변경), 블러링(노이즈)
가명화	매핑 테이블	- 원 데이터와 매핑되는 가명 테이블 생성
	해시 함수	- 해시값으로 이름 등 대체
해부화	데이터 구조 변경	- 테이블을 분할하여 식별자 부분을 분리해 냄

개인정보 비식별화

☐ 통계 기반 비식별화

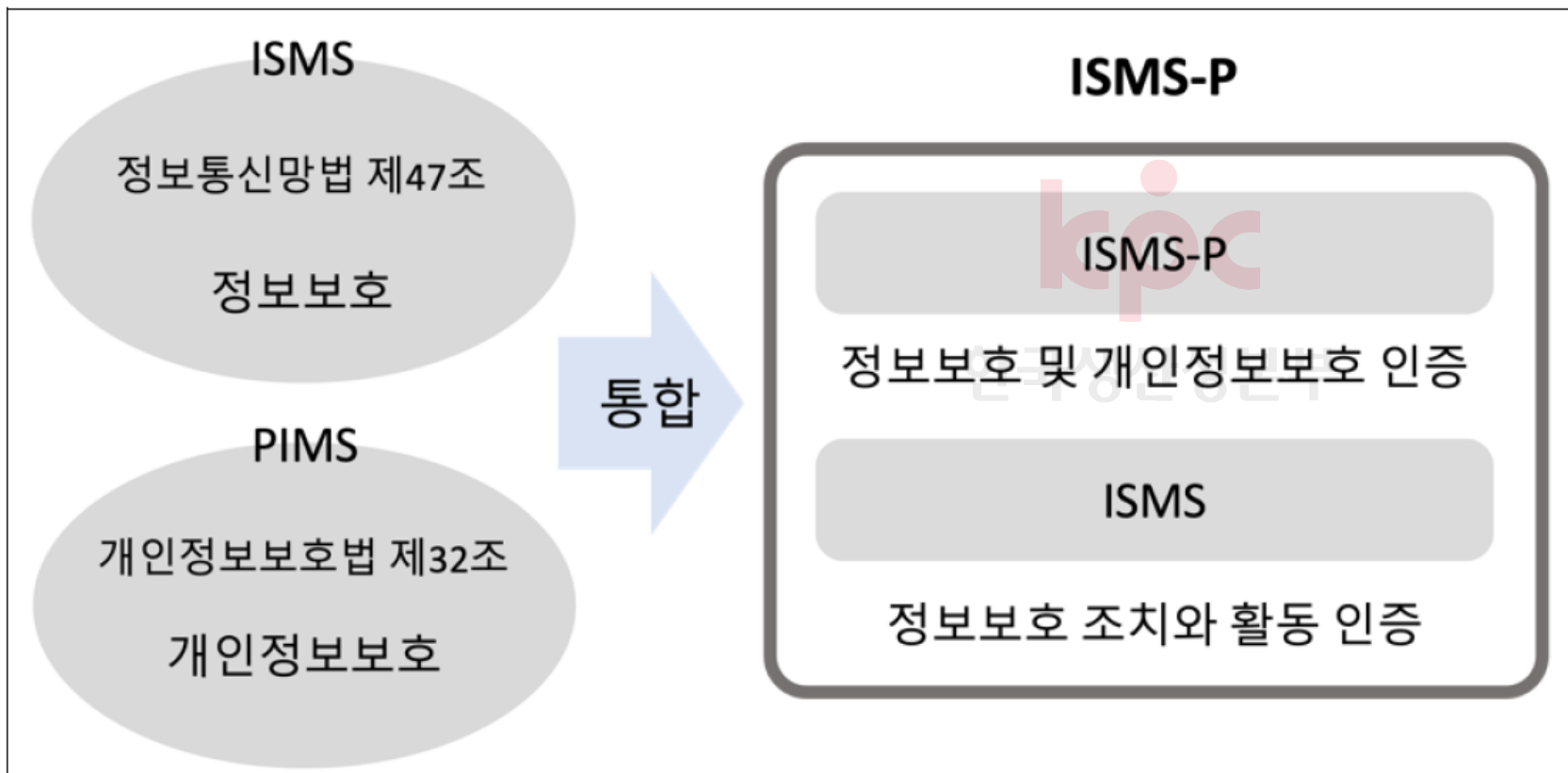
유형	상세 유형	설명
통계 활용	표본 추출	- 샘플 데이터는 모집단에 비해 식별 위험이 상대적으로 적음
	총계 처리	- 평균값, 최대값, 최소값, 중간값 등으로 대체
일반화	라운드	- 일반 라운드, 랜덤 라운드, 제어 라운드, 로컬 라운드
	상하단 코딩	- 정규 분포의 양끝단 값을 범주화
무작위화	잡음 추가	- 입원일자에 +3일 추가 시 퇴원일자에도 +3일 추가
	순열	- 동일집합 내에서 data를 재배열 해 식별자와 data 비매치
재현 데이터	완전 재현	- 원본 데이터를 포함하지 않음
	부분 재현	- 원본을 포함하되, 일부 민감 속성만 재현 데이터로 대체
	복합 재현	- 원본과 재현 데이터를 모두 활용하여 재현 데이터 생성

- 비식별화 정도가 높을수록 데이터의 유용성은 떨어지지만 프라이버시 침해 위험도는 낮아짐

ISMS-P

1. 정보서비스와 개인정보의 통합 보안인증, ISMS-P의 개요

□ ISMS-P의 개요



- 기존 정보보호 관리체계 인증제도(ISMS)와 개인정보보호 관리체계 인증제도(PIMS)를 단일제도에서 체계적으로 보호할 수 있도록 통합한 인증제도

ISMS-P

2. ISMS-P 의 의무대상

☐ ISMS-P 의 의무대상

ISP	IDC	그 외
- 전기통신사업법 제 6 조 1 항 - 정보통신망서비스 제공하는 자	- 정보통신망법 제 46 조 - 집적정보통신시설 사업자	- 연간 매출액 1,500 억원 이상 : 상급 종합 병원, 학교 - 전년도 매출 100 억원 이상 정보 통신 서비스 - 전년도 직전 3 개월 일평균 이용자 수 100 만명 이상 정보 통신 서비스

ISMS-P

3. ISMS-P 의 인증기준

□ ISMS-P 의 인증기준 요약



2.1 정책, 조직, 자산관리

2.2 인적보안

2.3 외부자보안

2.4 물리보안

2.5 인증 및 권한관리

2.6 접근통제

2.7 암호화 적용

2.8 정보시스템 도입 및 개발보안

2.9 시스템 및 서비스 운영관리

2.10 시스템 및 서비스 보안관리

2.11 사고 예방 및 대응

2.12 재해복구

3.1 개인정보 수집 시 보호 조치

3.2 개인정보 보유 및 이용 시 보호조치

3.3 개인정보 제공 시 보호조치

3.4 개인정보 파기 시 보호조치

3.5 정보주체 권리보호

ISMS-P

□ ISMS-P 의 인증기준 상세

항목	통제항목
1. 관리체계 수립 및 운영(16)	1.1 관리체계 기반 마련(6) 1.2 위험관리(4) 1.3 관리체계 운영(3) 1.4 관리체계 점검 및 개선(3)
2. 보호대책 요구사항(64)	2.1 정책 조직, 자산관리(3) 2.2 인적보안(6) 2.3 외부자 보안(4) 2.4 물리보안(7) 2.5 인증 및 권한 관리(6) 2.6 접근통제(7) 2.7 암호화 적용(2) 2.8 정보시스템 도입 및 개발 보안(6) 2.9 시스템 및 서비스 운영관리(7) 2.10 시스템 및 서비스 보안관리(9) 2.11 사고 예방 및 대응(5) 2.12 재해복구(2)
3. 개인정보 처리단계별 요구사항(21)	3.1 개인정보 수집 시 보호조치(7) 3.2 개인정보 보유 및 이용 시 보호조치(5) 3.3 개인정보 제공 시 보호조치(3) 3.4 개인정보 파기 시 보호조치(3) 3.5 정보주체 권리보호(3)

디지털 보안

7. 침해사고 대응

kpc

한국생산성본부

KPC 정보관리기술사 기본반



7. 침해사고 대응

컴퓨터 포렌식(Computer Forensics).....	96
안티 포렌식(Anti-Forensics)	100



컴퓨터 포렌식(Computer Forensics)

1. 사이버 범죄의 증거 확보, 컴퓨터 포렌식의 개요

□ 컴퓨터 포렌식(Computer Forensic)의 정의

- 컴퓨터를 매개로 이루어지는 범죄행위에 대한 법적 증거자료 확보를 위하여 컴퓨터 저장매체 등의 컴퓨터 시스템과 네트워크로부터 자료를 수집, 분석 및 보존하여, 디지털 자료가 법적 증거물로서 제출할 수 있도록 하는 일련의 절차 및 방법

□ 디지털 증거의 특징

특징	설명
디지털 데이터	- 디지털 데이터는 무제한 복제가 가능하여 원본 데이터와 복사본의 구분이 어려움
비가시성	- 디지털 데이터는 가시적으로 확인할 수 없어 적발과 그 증빙이 난해함
취약성	- 변조와 손상이 용이하고, 변조사실을 탐지하기 어려움 - 법정에서 조작 여부, 증거 획득 절차의 적법성 문제가 존재
대용량	- 대용량 데이터베이스 파일 등의 데이터의 경우 양이 방대함 - 전문가와 전용 분석도구 없이 범죄의 단서나 증거를 찾는 것이 어려움

컴퓨터 포렌식(Computer Forensics)

□ 디지털 포렌식 5 원칙

원칙	설명
정당성 원칙	- 증거는 적법한 절차를 거쳐서 수집해야 함 - 위반시, 증거효력상실
재현의 원칙	- 동일한 조건과 상황에서 항상 같은 결과 재현 보장
연계 보관성의 원칙	- 증거를 획득, 이송, 분석, 보관, 법정제출의 일련의 과정이 명확하며, 추적 가능해야 함
무결성의 원칙	- 수집된 정보는 각 단계를 거치는 과정에서 위변조 되지 않음을 입증해야 함
신속성의 원칙	- 증거 수집 과정은 신속히 진행되어야 함

컴퓨터 포렌식(Computer Forensics)

2. 컴퓨터 포렌식 분석시스템의 기능

구분	내용
디지털증거의 획득/ 무결성 검증 기능	- 무결성 검증: MD5 Hash, CRC Check - 디스크 이미지 복제 및 압축: 이미지 복제, 압축 및 분할 저장 지원
파일 복구기능	- 삭제 또는 손상된 파일 복구
고급 검색 기능	- 파일명, String 등에 대한 검색 - 이메일 데이터에 대한 Search - 웹 히스토리 검색 - 파일 슬랙에 대한 검색
기타	- 변조확장자 검색 (예: 내용은 Doc 파일인데 확장자가 Doc 파일이 아닌경우) - 주요 문서파일 분류 - 암호파일 검색

컴퓨터 포렌식(Computer Forensics)

3. 컴퓨터 포렌식 절차 및 포렌식 기술

□ 포렌식 절차

단계	단계명	주요활동	
1 단계	수사준비	- 압수수색영장 - 진술서 양식 - 자문가 연락처	- 관리자승인 - 현장 채증 장비 - 증거분석 툴
2 단계	증거획득	- 획득과정 기록(현장상황, 시스템구성) - 메모리덤프, 디스크 복사, 해싱 - 네트워크.서버(로그, 히스토리, 디렉토리) - 관리자 진술/서명	
3 단계	보관이송	- 전자파 차폐용기 - 디스크 또는 파일 해시 값 관리 - 적절한 온도, 습도 유지 - 라벨링	- 반출/입 통제 - 쓰기 금지 - 회피물체(자성체, X-RAY)
4 단계	검증분석	- 분석과정명확 - 결과도출 논리적 - 증거물 훼손 및 내용 변경 금지 - 백업본 사용 분석	- 기록 유지 - 재현가능 - 다양한 기법 사용
5 단계	조사보고	- 쉽고 평이하게 기술 - 삭제파일	- 과정을 명확하게 기록 - 발견장소, 경로 등

컴퓨터 포렌식(Computer Forensics)

□ 컴퓨터 포렌식의 주요기술

분류	기술	설명
수집기술	디스크 이미징	- 원본 디스크에 손상이나 변경 없이 원본 디스크를 물리적으로 동일하게 복제하거나 미러 이미지 파일을 생성
	메모리 덤프	- 프로세스가 사용중인 가상 메모리의 덤프를 획득하여 유용한 정보 획득
	무결성 입증	- 증거가 변경되지 않았음을 입증하기 위한 해쉬나 메시지 다이제스트 사용

컴퓨터 포렌식(Computer Forensics)

분석기술	Timeline 분석	- 파일의 생성시간, 최근 접근시간, 수정시간 분석 - 파일 시스템에 대한 사용로그 분석
	삭제된 파일 복구	- 클러스터들에 대한 정보 분석을 통한 삭제 파일 복구 - 복구가 불가능한 경우에도 파일 존재여부를 증명 가능함
	비정상 파일 검색	- 숨김 속성의 파일 및 확장자가 바뀐 파일 검색 - 파일 생성시 헤더에 고유 정보를 이용한 확장자 변경 확인
	이메일 분석	- 삭제된 파일 복구와 유사하게 이메일 복구 - 이메일 삭제시 이메일 헤더 값을 바꾸는 것으로 복구가능성이 높음
	슬랙공간 분석	- 클러스터의 남는 공간인 슬랙 공간에 데이터를 은닉 - 슬랙 공간 데이터에 대한 분석을 통한 증거 확보
	암호복구	- 시스템 또는 파일에 설정된 암호를 크랙하기 위한 기술
	덤프메모리 분석	- 코드영역, 데이터 영역, 스택 영역에 대한 분석

안티 포렌식(Anti-Forensics)

1. 안티 포렌식의 개요

□ 안티 포렌식(Anti-Forensic)의 정의

- 데이터의 영구 삭제, 데이터 암호화, 데이터 은닉 및 조작 등을 통하여 디지털 포렌식 수사에 의하여 증거가 발견되지 않도록 하기 위한 기술

□ 안티 포렌식의 목적

- 탐지를 회피하거나 정보 수집을 방해
- 조사관의 분석 시간을 증가
- 디지털 포렌식 도구가 동작하지 못하도록 하거나 오류를 발생
- 범죄자의 사용 흔적이나 도구 실행 흔적을 발견하지 못하도록 로깅을 차단/우회하거나 삭제
- 법정 보고서나 증언으로서 가치가 없도록 증거를 훼손

안티 포렌식(Anti-Forensics)

2. 안티 포렌식 기술

구분	기술	내용
데이터 삭제	디가우징 (Degaussing)	- 자기 테이프와 디스크 미디어에 있는 데이터나 신호들을 완전히 제거하기 위한 장치인 디가우저(Degaussers)를 이용하여 자기 장치를 강력한 자기장에 노출시킴으로 데이터를 영구 삭제하는 기술
	하드디스크 및 파일 와이핑 (Wiping)	- 파일을 완전히 복구할 수 없도록 파일의 엔트리 정보를 가지고 있는 영역과 해당 클러스터 영역을 '난수' 혹은 '0'으로 중복 덮어 쓰는 기술 - 덮어쓰기는 목적에 따라 디스크 전체를 대상으로 하거나 파일을 대상.
	증거 데이터 자동 삭제	- 분석을 어렵게 할 목적으로 흔적이 저장되는 웹 브라우저 흔적, 로그 파일, 프리패치, 최근 열린 파일, 검색 정보 등을 자동으로 삭제시키는 기술 - 주요 대상: 웹페이지, 문서, 그림, 동영상, 음성파일, 이메일, 레지스트리, 쿠키, 히스토리 - 도구: CCleaner, Evidence Eliminator, Windows Washer 등

안티 포렌식(Anti-Forensics)

데이터 은닉 및 변조	스테가노그래피 (Steganography)	- 메시지가 전송되고 있다는 사실 자체를 은닉하여 데이터를 숨기는 정보 은닉 기술 - 주로 디지털 매체에 메시지를 은닉하여 전달함. JPEG, BMP, GIF, WAV, MP3, SWF 등과 같은 멀티미디어 파일이나 HWP, DOC, XLS, PPT, PDF 등과 같은 문서 파일을 이용 - 메시지가 전송되고 있다는 사실을 숨기는 기술.
	디스크 내 데이터 은닉	- 파티션으로 인한 슬랙공간 등 파일시스템 구조에서 낭비되는 영역에 데이터를 숨기는 기술
		- 슬랙 공간(Slack Space), NTFS MFT(Master File Table), 배드 블록(Bad Block), ext3 저널 파일, inode 예약된 공간 영역 등에 데이터를 숨김
	데이터 암호화	- 파일이나 디렉토리를 암호화하여 아무나 접근할 수 없도록 하는 기술 - 운영체제 자체에서 지원하는 암호화 기능을 이용하거나 별도의 암호화 전용 도구를 사용할 수 있음. 또한, 응용프로그램 자체적으로 암호화 기능을 지원하기도 함.
	데이터 변조 기술	- 코드 난독화(Code Obfuscation), 실행압축(Packing), 래핑(Wrapping) 등을 이용하여 디지털 포렌식 분석 시간을 증가시키는 기술

안티 포렌식(Anti-Forensics)

3. 안티 포렌식 대응 기술 현황

- 안티 포렌식 기법에 대응하기 위한 안티 안티 포렌식(Anti-Anti-Forensics) 기법에 대한 연구도 최근에 활발히 진행되고 있음.
- 대표적인 안티 안티 포렌식 기법으로는 데이터 복구, 비밀번호 크랙, 은닉 데이터 탐지, 휘발성 메모리 분석, 스테가노그래피 탐지 등이 있음

